



Contoso (synthetic)

contoso.onmicrosoft.com · 00000000-1111-2222-3333-444444444444

SCOPE

management group 00000000-
1111-2222-3333-444444444444

ASSESSED

08 Oct 2026

EVIDENCE

AzGovViz 6.7.2 · Azure Resource Graph ·
Azure review checklists @f131b93

GOVERNANCE MATURITY SCORE

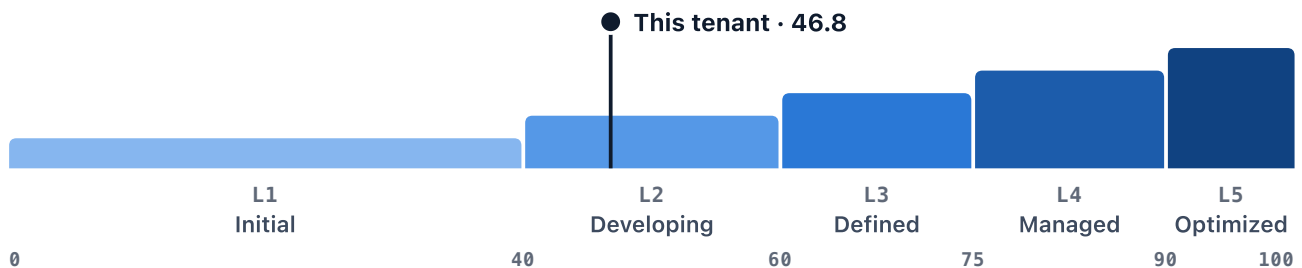
46.8

/100

Level 2 of 5

Developing

Foundational controls are partial; material risks remain.



Contoso is at maturity level 2 (Developing, 46.8/100): the landing-zone building blocks exist, but uncontrolled privileged access - standing root-scope rights, no PIM and 6 Owners on production - is the single most important thing to fix.

AI ANALYSIS · GITHUB COPILOT CLI (CLAUDE OPUS 5.5)

3

SUBSCRIPTIONS

50

RESOURCES

2

POLICY
ASSIGNMENTS

17

ROLE ASSIGNMENTS

12

HIGH-SEVERITY
GAPS

220

CHECKLIST ITEMS
TESTED

Read-only assessment. Evidence was collected with read permissions only; verify findings before acting. Not an official Microsoft attestation.

Confidential. Contains tenant configuration data (identities, scopes, resource names).

Prepared with the azgovviz-assessment 1.0.0 plugin for GitHub Copilot CLI.

Contents

1	Executive summary	3
2	Scores by design area	4
3	Top risks	6
4	Remediation roadmap	11
5	Findings	14
	Identity & Access	14
	Resource Organization	18
	Governance & Policy	21
	Security	25
	Network	29
	Management & Monitoring	30
	Cost Management	32
6	Azure review checklists	34
	Azure Landing Zone (ALZ) Review	34
	Well-Architected Framework (WAF) Review	34
	Azure Proactive Resiliency Library (APRL)	35
	All checklist items	35
7	Environment	46
8	Method and sources	48

1 Executive summary

MANAGEMENT GROUPS 3 depth 1	SUBSCRIPTIONS 3 3 enabled	RESOURCES 50 11 types · 3 regions	POLICY ASSIGNMENTS 2 1 at MG scope	ROLE ASSIGNMENTS 17 12 Owner	CHECKLIST ITEMS TESTED 220 325 Resource Graph queries
--	--	--	---	---	--

● High

12

High or critical gaps

● Medium

23

Medium gaps

● Low

16

Low gaps

● Passed

10

Controls in place

AI ANALYSIS · GITHUB COPILOT CLI (CLAUDE OPUS 5.5)

Contoso is at maturity level 2 (Developing, 46.8/100): the landing-zone building blocks exist, but uncontrolled privileged access - standing root-scope rights, no PIM and 6 Owners on production - is the single most important thing to fix.

Contoso's Azure estate (3 subscriptions, 50 resources) scores 46.8/100 - maturity level 2, Developing. Landing-zone foundations exist - a 'Landing zones' management group with the Microsoft cloud security benchmark (MCSB), hub-and-spoke networking and a central Log Analytics workspace - but they are applied unevenly and privileged access is largely uncontrolled. Resource organization (24.0) and cost management (36.7) sit at the Initial level; identity (42.8) and security (41.1) carry most of the risk. The assessment found 12 high-severity gaps and no critical ones.

Three issues matter most. **Privileged access:** 11 privileged user assignments are permanent and PIM is not used; they include User Access Administrator at the root scope '/' and a direct Owner on the Tenant Root Group - either account can take over every subscription - and Contoso-Prod has 6 Owners, two of them automation identities. **Exposed production data:** storage account st0 serves a container anonymously, all three storage accounts that accept TLS 1.0 are in production, and all 9 storage accounts and 3 key vaults accept traffic from any network. **An unwatched sandbox:** Contoso-Sandbox sits directly under the Tenant Root Group instead of the Sandbox management group, so no policy applies to it; it exports no activity log and has RDP open to the internet. Nothing prevents recurrence: no Deny policy is enforced, allowed locations runs in DoNotEnforce mode and 44% of evaluated resources are non-compliant.

What to do first. Within 30 days: remove the root-scope assignment and enforce MFA for owners, close the RDP rule, disable anonymous blob access and TLS 1.0, bring Contoso-Sandbox into the Sandbox management group under MCSB, and extend production's security contact, activity-log export and alerting to Dev and Sandbox. This low-effort 30-day plan closes at least 7 of the 12 high-severity findings. Within 90 days, move owners to PIM-eligible groups and enforce Deny guardrails and Defender plans from an intermediate-root management group so the fixes stay fixed. Limitation: most checklist items are manual, and some automated checklist results in this synthetic tenant contradict the inventory, so conclusions rest on platform findings and inventory evidence.

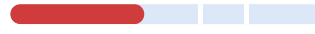
2 Scores by design area

Each score blends tenant-level governance checks (60%) with Azure review-checklist results (40%), weighted by severity. Ticks mark the Defined (60) and Managed (75) thresholds.

Identity & Access

RBAC model, privileged and standing access, guests, service principals

The platform score of 23.3 is the lowest of any area and drives the result: no PIM, 11 permanent privileged user assignments, User Access Administrator at the root scope and 82.4% of assignments made to individual users instead of groups. Scope hygiene is good (no redundant or resource-level assignments), so moving 17 assignments to groups with PIM is a contained change.

 **42.8**

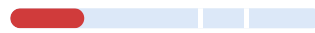
 **Developing**

7 fail · 5 warn · 2 pass
3/3 checklist items failing

Resource Organization

Management group hierarchy, subscription placement, naming and tagging

The weakest area at 24.0: the hierarchy has made a start (Landing zones and Sandbox groups, one level deep) but has no intermediate root or Platform group, new subscriptions default to the root and anyone can create management groups. Only 26.0% of resources are tagged, and the one automated checklist item (ALZ C02.14, tags for cost management) fails.

 **24**

 **Initial**

4 fail · 3 warn · 3 pass
1/1 checklist items failing

Governance & Policy

Azure Policy guardrails, compliance state, exemptions, ALZ policy currency

The highest-scoring area (64.3) because MCSB is assigned at management-group scope with built-in definitions and nothing is assigned at the Tenant Root Group. It is held back by the lack of prevention: no enforced Deny assignment, allowed locations only in DoNotEnforce, no tag policies and 44.0% of evaluated resources non-compliant.

 **64.3**

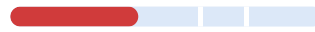
 **Defined**

2 fail · 9 warn · 3 pass
5/7 checklist items failing

Security

Defender for Cloud coverage, secure configuration, data exposure

Weak on data-plane hygiene - anonymous blob access on st0, TLS 1.0 on three production accounts, every storage account and key vault open to all networks - and on Defender coverage (CSPM on 1 of 3 subscriptions, average secure score 46.0%). 32 of 54 security checklist items fail, led by WAF 659ae558 (anonymous access) and e12be569 (TLS).

 **41.1**

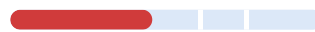
 **Developing**

5 fail · 6 warn · 0 pass
32/54 checklist items failing

Network

Topology, segmentation, private connectivity, internet exposure

A hub-and-spoke topology exists (vnet-hub peered with two spokes), but RDP is open to the internet in Contoso-Sandbox, the 'data' subnet in vnet-spoke2 has no NSG and is 91% used, and no VNet has DDoS Network Protection. A single private endpoint serves the 12 storage accounts and key vaults; 21 of 26 network checklist items fail.

 **45.4**

 **Developing**

1 fail · 3 warn · 1 pass
21/26 checklist items failing

Management & Monitoring

Logging, alerting, diagnostics, resource locks, backup

A central workspace (la-central, 30-day retention) is in place, but only Contoso-Prod exports its activity log and has a Service Health alert, no subscription has Resource Health alerts and there are no resource locks. 16 of 20 management checklist items fail, mostly monitoring coverage (VM Insights, NSG flow logs, Network Watcher).

 55.3

 Developing

0 fail · 3 warn · 1 pass
16/20 checklist items failing

Reliability & Resiliency

Zone redundancy, replication and DR (APRL and WAF reliability checks)

Scored from checklists only: 39 of 59 APRL/WAF reliability items fail. The pattern is locally redundant, non-zonal deployment - all 9 storage accounts are Standard_LRS and the production Application Gateway and AKS cluster are not zone-redundant - with incomplete VM replication and maintenance configuration.

 51.7

 Developing

0 fail · 0 warn · 0 pass
39/59 checklist items failing

Cost Management

Budgets, idle and orphaned resources, Advisor cost guidance

Only Contoso-Prod has a budget and it has no notifications, so overspend alerts reach no one. Waste is small but unmanaged: 2 orphaned or idle resources (an unattached disk in Contoso-Dev, an empty resource group in Contoso-Sandbox) and 2 VMs that Advisor recommends right-sizing.

 36.7

 Initial

0 fail · 3 warn · 0 pass
1/1 checklist items failing

Performance Efficiency

Scalability and performance configuration (WAF)

Checklist-only and the second-highest score (60.1). Failures concentrate on VM disk and SKU choices (APRL df0ff862 Premium/Ultra disks, 3201dba8 B-series VMs) and oversized address space (WAF 33aad5e8, e.g. the /16 hub); review them with workload owners rather than as platform controls.

 60.1

 Defined

0 fail · 0 warn · 0 pass
13/21 checklist items failing

3 Top risks

Prioritised by the AI analysis step from the evidence below.

● High IDENTITY & ACCESS

Standing, tenant-wide admin rights with no just-in-time control

WHY IT MATTERS	Two individual accounts can take over every subscription: 'Global Admin' keeps User Access Administrator at the root scope and 'Alice Admin' is a direct Owner of the Tenant Root Group. With no PIM and MFA missing on some owner accounts, one stolen credential would give an attacker full control of all resources, policies and logs.
EVIDENCE	IAM-006: 1 permanent User Access Administrator assignment at root '/' ('Global Admin'). IAM-007: 'Alice Admin' holds Owner directly at the Tenant Root Group, inherited by all 3 subscriptions. IAM-008: 0 PIM-managed assignments; 11 privileged user assignments are permanent. SEC-007: Defender for Cloud's 'MFA should be enabled on accounts with owner permissions' (High) is open on 2 accounts.
DO THIS	Now: remove the root-scope assignment (Entra ID > Properties > 'Access management for Azure resources' = No), alert on elevateAccess audit events and enforce MFA for every Owner through Conditional Access. Within 90 days: replace Alice Admin's direct Owner with a PIM-eligible platform-admin group (MFA, justification and approval on activation) and convert the remaining permanent assignments to PIM eligibility, keeping two documented break-glass accounts.

IAM-006

IAM-007

IAM-008

SEC-007

● High IDENTITY & ACCESS

Too many Owners on production, including automation identities

WHY IT MATTERS	Every Owner can change access, policy and logging in production. A leaked pipeline credential would hand an attacker the production subscription - including the hub network and central Log Analytics workspace that live in it - and guest accounts hold write access in all three subscriptions.
EVIDENCE	IAM-004: Contoso-Prod has 6 Owner principals (4 users, 0 groups, 2 service principals); Contoso-Dev and Contoso-Sandbox have 4 each. IAM-002: service principal 'deploy-pipeline' is Owner on Contoso-Prod. IAM-011: policy identity 'policy-mi' (assignment 'Deploy diag') is Owner on Contoso-Prod. IAM-005: 14 of 17 assignments (82.4%) target individual users, none target groups. IAM-001: 3 guests hold direct Contributor, one per subscription. IAM-010: co-administrator old@contoso.com remains on Contoso-Prod.
DO THIS	Reduce Contoso-Prod to 2-3 Owners through a PIM-eligible group and move day-to-day administrators to Contributor. Give deploy-pipeline Contributor (or a custom role) on its target resource groups and switch it to workload identity federation; give policy-mi only the roles its policy definition lists; remove the co-administrator; remove the guests or make their access time-bound with access reviews (Azure Lighthouse for partners).

IAM-004

IAM-002

IAM-011

IAM-005

IAM-001

IAM-010

● High GOVERNANCE & POLICY

Guardrails audit but do not prevent, and miss the sandbox

WHY IT MATTERS	Nothing stops a user from creating a publicly readable storage account, opening RDP to the internet or deploying outside approved regions - which is how the exposures in this report arose. Audit-only policy has not changed behaviour: almost half of the evaluated resources are non-compliant.
EVIDENCE	The policy inventory records 2 assignments (GOV-001): MCSB at the 'Landing zones' management group and 'Allowed locations' on Contoso-Prod in DoNotEnforce mode (GOV-004), so allowed locations is enforced on 0 of 3 subscriptions (GOV-003) while resources run in westeurope (30), northeurope (12) and eastus (8). 0 enforced single-policy Deny assignments (GOV-005). MCSB covers 2 of 3 subscriptions; Contoso-Sandbox is missing (GOV-002). 22 of 50 evaluated resources (44.0%) are non-compliant (GOV-015) and 7 await DeployIfNotExists remediation (GOV-014).
DO THIS	Assign MCSB once at an intermediate-root management group so every subscription inherits it. After a 2-4 week audit period, enforce Deny for allowed locations (resources and resource groups, replacing the DoNotEnforce assignment), storage anonymous access, minimum TLS 1.2 and inbound management ports from the internet. Triage the 22 non-compliant resources: remediate, exempt with an expiry date, or adjust the policy.

GOV-002

GOV-003

GOV-004

GOV-005

GOV-015

GOV-014

● High SECURITY

Production storage and key vaults are reachable from the internet

WHY IT MATTERS	An anonymous container can be read by anyone who finds its URL, and TLS 1.0 plus open network access widen the attack surface of production data. With Defender for Storage off, misuse of these accounts would go undetected.
EVIDENCE	SEC-008: st0 (Contoso-Prod) exposes 1 container anonymously; 3 of 9 accounts (st0, st4, st8) allow anonymous access. SEC-009: st0, st3 and st6 - all in Contoso-Prod - accept TLS 1.0. SEC-010: 9 of 9 storage accounts and 3 of 3 key vaults accept traffic from any network; the only private endpoint is pe-kv0 (NET-005). SEC-003: Defender for Storage is off on Contoso-Prod. SEC-011: kv1 and kv2 have purge protection disabled. WAF items 659ae558 and e12be569 (High) fail for the same reasons.
DO THIS	Confirm who uses st0's public container, move them to SAS or Entra ID access and disable anonymous access on st0, st4 and st8; set minimum TLS 1.2 on st0, st3 and st6; enable Defender for Storage on Contoso-Prod (it is also off on Contoso-Dev); enable purge protection on kv1 and kv2. Then restrict network access - storage firewall with trusted services first, private endpoints with central private DNS next - starting with Contoso-Prod.

SEC-008

SEC-009

SEC-010

SEC-003

SEC-011

NET-005

● High NETWORK

RDP open to the internet in an unwatched sandbox subscription

WHY IT MATTERS	Internet-facing RDP is scanned and brute-forced continuously. Here it sits in the least-governed subscription - no policy, no security contact, no exported activity log - so a compromise would likely go unnoticed. The sandbox VNet is not peered to the hub, which limits but does not remove the impact.
EVIDENCE	NET-001: NSG nsg-jump rule 'allow-rdp' allows port 3389 from any source (*) in Contoso-Sandbox. The subscription sits directly under the Tenant Root Group rather than in the existing 'Sandbox' management group (ORG-001), so no policy assignment reaches it and MCSB is missing (GOV-002). It has no security contact (SEC-005), no activity-log export (MGT-001) and no Service Health alerts (MGT-003), and Defender for Servers is not enabled there (inventory), so just-in-time VM access is unavailable. vnet-lab has no peerings (NET-002).
DO THIS	Delete 'allow-rdp' now and use Azure Bastion, or enable Defender for Servers and its just-in-time VM access. Move Contoso-Sandbox into the 'Sandbox' management group, apply the production baseline (security contact, activity-log export, Service Health alerts) and enforce a Deny policy for inbound management ports from the internet at management-group scope.

NET-001

ORG-001

GOV-002

SEC-005

MGT-001

MGT-003

● Medium SECURITY

Threat detection and audit trail cover only part of the estate

WHY IT MATTERS	Outside Contoso-Prod, control-plane attacks and administrative changes are neither detected nor retained centrally and Defender alerts reach no one, so incidents in Dev or Sandbox would surface late. Production itself runs without Defender CSPM and has the lowest secure score.
EVIDENCE	SEC-001: Defender CSPM is on for 1 of 3 subscriptions (Contoso-Sandbox only). SEC-004: Defender for Resource Manager on 1 of 3. SEC-005: security contact on 1 of 3. MGT-001: activity-log export on 1 of 3. MGT-003: Service Health alerts on 1 of 3, Resource Health alerts on 0. SEC-006: average secure score 46.0%, lowest on Contoso-Prod at 36.0%. MGT-002: the central workspace la-central keeps data for 30 days.
DO THIS	Assign the Defender for Cloud and diagnostics DeployIfNotExists policies at management-group scope: Defender CSPM and Defender for Resource Manager on every subscription, a security-operations contact with notifications from Medium severity, activity logs to la-central and Azure Monitor Baseline Alerts for Service and Resource Health. Review the 30-day retention against investigation needs, and work Contoso-Prod's secure-score recommendations first with Defender governance rules (owners and due dates).

SEC-001

SEC-004

SEC-005

SEC-006

MGT-001

MGT-003

● Medium RESOURCE ORGANIZATION

Incomplete landing-zone structure lets subscriptions and shared services drift

WHY IT MATTERS	Without an intermediate root and a Platform group, every new subscription lands at the root with no guardrails – exactly how Contoso-Sandbox ended up outside them – and shared services inherit production's access model. Sparse tagging makes ownership and cost hard to trace.
EVIDENCE	ORG-003: no Platform management group; vnet-hub (NET-002) and la-central (MGT-002) both live in Contoso-Prod. ORG-006: new subscriptions default to the Tenant Root Group. ORG-007: any user can create management groups. ORG-001: 1 of 3 subscriptions sits directly under the root. ORG-008: 26.0% of resources (13/50) and 25.0% of resource groups (3/12) carry tags. ORG-009: 2 of 3 subscriptions have no tags.
DO THIS	Create an intermediate-root management group with Platform, Landing zones, Sandbox and Decommissioned beneath it; make Sandbox the default for new subscriptions and require write permission to create management groups. Define mandatory tags (owner, costCenter, environment, application) and enforce them with policy. At this size one platform subscription is enough; move the hub and la-central into it as the estate grows.

ORG-003 ORG-006 ORG-007 ORG-001 ORG-008 ORG-009

● Medium RELIABILITY & RESILIENCY

Locally redundant data and non-zonal production services

WHY IT MATTERS	A zone outage or accidental deletion could take production services down or lose data: availability currently rests on single-zone deployments and locally redundant storage rather than on design.
EVIDENCE	39 of 59 evaluated APRL/WAF reliability items fail (resiliency score 51.7, checklist-only). All 9 storage accounts use Standard_LRS (inventory). In Contoso-Prod the Application Gateway is not zone-redundant (APRL c9c00f2a) and the AKS cluster is not spread across zones (APRL 4f63619f). 3 of 6 VMs lack maintenance configurations (APRL 52ab9e5c) and 3 of 6 lack Site Recovery replication (APRL cfe22a65). No resource locks exist (MGT-004) and kv1/kv2 lack purge protection (SEC-011).
DO THIS	Agree RTO/RPO per workload, then for production move business data to ZRS or GZRS, run the Application Gateway and AKS across availability zones, protect VMs with Azure Backup and Site Recovery where the RTO requires it, add maintenance configurations, put CannotDelete locks on shared platform resource groups and test a failover at least once a year.

MGT-004 SEC-011

What is working

- ✓ A management-group hierarchy exists and is shallow: 'Landing zones' holds Contoso-Prod and Contoso-Dev, a 'Sandbox' group is ready, and no group is more than 1 level below the root (ORG-002, ORG-004, ORG-005).
- ✓ The Microsoft cloud security benchmark is assigned at management-group scope ('Landing zones', Default enforcement); both policy assignments use built-in definitions and none is made at the Tenant Root Group (GOV-001, GOV-006, GOV-007).
- ✓ Contoso-Prod already runs the target operations baseline – activity-log export, a security contact with alert notifications, a Service Health alert and Defender for Servers, Resource Manager and App Service – ready to be templated to Dev and Sandbox.

- ✓ Hub-and-spoke networking is in place (vnet-hub peered with vnet-spoke1 and vnet-spoke2) and logs go to a central Log Analytics workspace, la-central (NET-002, MGT-002).
- ✓ Baseline data-protection settings are on: secure transfer (HTTPS only) on all 9 storage accounts, soft delete on all 3 key vaults, and kv0 combines purge protection, Azure RBAC and a private endpoint (pe-kv0).
- ✓ RBAC sits at sensible scopes: 15 of 17 assignments are at subscription scope, none at resource-group or resource level, and none duplicates an inherited assignment (IAM-013, IAM-014).

4 Remediation roadmap

Sequenced by the AI analysis step.

Now (0-30 days)

1 Remove standing root access and legacy privileges

Have 'Global Admin' set 'Access management for Azure resources' to No (Entra ID > Properties) to drop User Access Administrator at root '/', and alert on elevateAccess audit events. Enforce MFA through Conditional Access for every account with Owner (Defender flags 2 without it). Remove co-administrator old@contoso.com from Contoso-Prod, delete the orphaned Reader assignment 'deadbeef' on Contoso-Dev, delete the unassigned 'Custom Owner' role ('*' actions) and remove any of the 3 guest Contributor assignments that are no longer needed.

effort low · Identity team (Entra ID administrators) **IAM-006** **SEC-007** **IAM-010** **IAM-003** **IAM-009** **IAM-001**

2 Lock down exposed production storage and key vaults

Confirm who consumes st0's anonymous container, move them to SAS or Entra ID access, then set 'Allow Blob anonymous access' to Disabled on st0, st4 and st8. Set minimum TLS 1.2 on st0, st3 and st6. Enable Defender for Storage on Contoso-Prod (and Contoso-Dev). Enable purge protection on kv1 and kv2 - it cannot be switched off afterwards, which is the point.

effort low · Workload owners with the security team **SEC-008** **SEC-009** **SEC-003** **SEC-011**

3 Close internet RDP and bring Contoso-Sandbox under governance

Delete rule 'allow-rdp' (3389 from any source) on nsg-jump and use Azure Bastion or Defender for Servers just-in-time access for admin sessions. Move Contoso-Sandbox into the existing 'Sandbox' management group and assign MCSB there (consolidated at the intermediate root in the next phase). Make 'Sandbox' the default management group for new subscriptions and require write permission to create management groups.

effort low · Platform team **NET-001** **ORG-001** **GOV-002** **ORG-006** **ORG-007**

4 Extend the production operations baseline to every subscription

Contoso-Prod already has a security contact with alert notifications, activity-log export and a Service Health alert; configure the same on Contoso-Dev and Contoso-Sandbox, enable Defender for Resource Manager on both, add Resource Health alerts on all 3 subscriptions and put CannotDelete locks on the resource groups holding vnet-hub and la-central. Do it by hand now; policy takes over in the next phase.

effort low · Platform team / Security operations **SEC-005** **SEC-004** **MGT-001** **MGT-003** **MGT-004**

5 Turn on budget alerts and remove obvious waste

Create a monthly budget with 80%/100% actual and 110% forecast alerts on every subscription and add notifications to the existing Contoso-Prod budget (500), which currently alerts no one. After owner confirmation, delete the unattached disk in Contoso-Dev, the empty resource group in Contoso-Sandbox and the unattached Standard public IP pip3 in Contoso-Prod; act on Advisor's right-sizing recommendation for 2 VMs.

effort low · FinOps / subscription owners **CST-001** **CST-002** **CST-003**

Next (30-90 days)

1 Move privileged access to PIM-eligible groups

Create Entra ID groups per scope and role (for example platform owners, prod contributors) and make them PIM-eligible with MFA, justification and approval for Owner (PIM needs Entra ID P2 or ID Governance licences). Replace Alice Admin's direct Owner at the Tenant Root Group and the 9 permanent subscription Owner assignments, keep 2-3 Owners per subscription (Contoso-Prod has 6) and move day-to-day administrators to Contributor. Make remaining guest access time-bound with quarterly access reviews; keep two documented break-glass accounts.

effort medium · Identity team **IAM-008** **IAM-007** **IAM-004** **IAM-005** **IAM-001**

2 Least-privilege automation identities

Replace deploy-pipeline's Owner on Contoso-Prod with Contributor (or a custom role) on the resource groups it deploys to, and move it to workload identity federation instead of secrets. Replace policy-mi's Owner with the roles listed in the 'Deploy diag' policy definition, then run the remediation task for the 7 non-compliant resources.

effort medium · DevOps / Platform team **IAM-002** **IAM-011** **GOV-014**

3 Complete the management-group hierarchy

Create an intermediate-root management group (for example 'Contoso') under the Tenant Root Group with Platform, Landing zones, Sandbox and Decommissioned beneath it, and move the existing groups under it. Delete the unused custom policy 'Old custom' stored at the Tenant Root Group and keep future custom definitions at the intermediate root, managed as code. At 3 subscriptions, one Platform group without Identity/Connectivity/Management children is enough.

effort medium · Cloud architecture / Platform team **ORG-003** **GOV-016** **GOV-012**

4 Enforce preventive guardrails at the intermediate root

Re-assign MCSB once at the intermediate root (replacing the 'Landing zones' and 'Sandbox' assignments). After a 2-4 week audit period enforce with Deny: Allowed locations and Allowed locations for resource groups (decide whether eastus, with 8 resources today, is approved, and retire the DoNotEnforce assignment on Contoso-Prod), storage anonymous access disallowed, minimum TLS 1.2, no management ports from the internet, subnets must have an NSG (fix the 'data' subnet in vnet-spoke2 first) and not-allowed resource types. Add tag policies for owner, costCenter and environment. Triage the 22 non-compliant resources and give the 'legacy-app' waiver an expiry date.

effort medium · Platform team / Cloud governance **GOV-002** **GOV-003** **GOV-004** **GOV-005** **GOV-008** **GOV-009** **GOV-011** **GOV-015** **NET-003**

5 Deploy Defender and monitoring by policy

From the intermediate root, assign DeployIfNotExists policies for Defender CSPM (today only on Contoso-Sandbox) and the plans matching deployed services (Servers, Storage, Key Vault, Resource Manager, Containers), security contacts, activity-log export to Ia-central and Azure Monitor Baseline Alerts for Service and Resource Health. Review Ia-central's 30-day retention against incident-response needs. Work Contoso-Prod's secure score (36%) first, using Defender governance rules with owners and due dates.

effort medium · Security operations / Platform team **SEC-001** **SEC-004** **SEC-005** **SEC-006** **MGT-001** **MGT-003**

Later (90-180 days)

1 Private connectivity for data services

Deploy private endpoints with centrally managed, policy-driven private DNS zones for the 9 storage accounts and 3 key vaults, starting with Contoso-Prod, then disable public network access - kv0 has a private endpoint (pe-kv0) but still accepts public traffic. Follow with Deny policies on public network access, migrate kv2 to the Azure RBAC permission model, and evaluate DDoS protection for the 3 attached public IPs in Contoso-Prod (no VNet has DDoS Network Protection).

effort high · Network team with workload owners **SEC-010** **NET-005** **SEC-012** **NET-006**

2 Separate platform services from production

vnet-hub and Ia-central live in Contoso-Prod, so production Owners control shared connectivity and logs. Move them into one platform subscription under the Platform management group (enough at this scale), re-apply the CannotDelete locks, and re-plan address space - including the 'data' subnet in vnet-spoke2 (/28, 91% used).

effort high · Cloud architecture / Network team **ORG-003** **NET-002** **NET-004**

3 Build resilience into production workloads

Agree RTO/RPO per workload, then move business data from LRS to ZRS/GZRS (all 9 storage accounts are Standard_LRS), redeploy the Application Gateway and AKS cluster across availability zones (APRL c9c00f2a, 4f63619f), protect VMs with Azure Backup and Site Recovery where the RTO requires it (APRL 1981f704, cfe22a65), add maintenance configurations (APRL 52ab9e5c) and run a failover test.

effort high · Workload owners / Platform team

4 Tagging and naming standard

With tag policies in place, back-fill owner, costCenter, environment and application tags (26.0% of resources and 25.0% of resource groups are tagged today; Contoso-Dev and Contoso-Sandbox have no subscription tags) using Modify/inherit policies and remediation tasks. Adopt the CAF naming convention in IaC modules - 6 storage accounts do not follow it.

effort medium · Platform team / FinOps **ORG-008** **ORG-009** **ORG-010**

5 Make this assessment a quarterly control

Re-run the assessment every quarter with a dedicated identity that holds Reader only (this run used an identity with Owner) and compare against this run with --baseline; track secure score, policy compliance and maturity level as KPIs.

effort low · Cloud governance lead **IAM-012**

Quick wins

Low-effort fixes for medium-or-higher gaps.

- **Standing access at the root scope '/' (elevated access)** – Remove root-scope assignments (Entra ID > Properties > 'Access management for Azure resources' = No) and alert on 'elevateAccess' events in the Entra ID audit log.
- **Management ports (SSH/RDP) open to the internet** – Remove the rules; use Azure Bastion or Defender for Servers just-in-time VM access, and deny inbound management ports from the internet with policy.
- **Defender workload protection for deployed services** – Enable the Defender plans that match deployed services; Resource Manager and Key Vault plans are low-cost and protect the control plane.
- **Anonymous (public) blob access** – Set 'Allow Blob anonymous access' to Disabled on every account (policy: 'Storage account public access should be disallowed', Deny) and use SAS/Entra ID for sharing.
- **Security baseline initiative (Microsoft cloud security benchmark)** – Assign the 'Microsoft cloud security benchmark' initiative at the intermediate-root management group (Defender for Cloud does this per subscription by default).
- **Guest accounts with privileged or write access** – Remove or downgrade guest privileged assignments; if external admins are required use Azure Lighthouse or PIM-eligible, time-bound assignments with access reviews.
- **Defender Cloud Security Posture Management (CSPM)** – Enable Defender CSPM on all subscriptions (assign the Defender for Cloud plan policies at the intermediate-root management group).
- **Data residency guardrail (allowed locations)** – Assign 'Allowed locations' and 'Allowed locations for resource groups' (Deny) at the intermediate-root management group with your approved regions.

5 Findings

Tenant-level checks computed from AzGovViz output and Azure Resource Graph, grouped by design area. Gaps are shown with evidence and the recommended fix; passed and informational checks are listed in one line each.

Identity & Access

RBAC model, privileged and standing access, guests, service principals

score 42.8

Fail

High

Service principals with Owner or User Access Administrator

1 service principal/managed identity assignments grant Owner-level rights at subscription or higher scope (1 in total).

IAM-002

WHY IT MATTERS

A compromised automation credential with Owner can change RBAC and policy, disable logging and exfiltrate data. Pipelines rarely need more than Contributor on a narrow scope.

RECOMMENDATION

Replace Owner with least-privilege roles (Contributor or custom) scoped to the target resource groups; use workload identity federation instead of secrets; review regularly.

Effort: medium · Source: AzGovViz RoleAssignments

EVIDENCE

PRINCIPAL	TYPE	ROLE	SCOPE
deploy-pipeline	SP APP INT	Owner	Sub Contoso-Prod

Azure RBAC best practices

Fail

High

Standing access at the root scope '/' (elevated access)

1 assignments at root scope '/' (e.g. elevated Global Administrator access) remain active.

IAM-006

WHY IT MATTERS

'Elevate access' grants User Access Administrator over every subscription and management group. It is meant for break-glass use and should be removed immediately afterwards.

RECOMMENDATION

Remove root-scope assignments (Entra ID > Properties > 'Access management for Azure resources' = No) and alert on 'elevateAccess' events in the Entra ID audit log.

Effort: low · Source: AzGovViz RoleAssignments

EVIDENCE

PRINCIPAL	TYPE	ROLE
Global Admin	User Member	User Access Administrator

Elevate access to manage all Azure subscriptions

Fail

High

Just-in-time access with Privileged Identity Management

No PIM-managed Azure role assignments detected; 11 privileged user assignments are permanent (standing access).

IAM-008

WHY IT MATTERS

Standing Owner/User Access Administrator rights are exploitable 24x7. PIM makes privileged roles eligible, time-bound, approved and audited. (PIM requires Microsoft Entra ID P2 / Governance.)

RECOMMENDATION

Convert permanent privileged assignments to PIM-eligible assignments (prefer PIM for groups), require MFA + justification on activation, and run quarterly access reviews.

Effort: medium · Source: AzGovViz RoleAssignments

EVIDENCE

PRINCIPAL	ROLE	SCOPE	PIM
Alice Admin	Owner	MG 00000000-1111-2222-3333-444444444444	False
Owner0a	Owner	Sub Contoso-Prod	False
Owner0b	Owner	Sub Contoso-Prod	False
Owner0c	Owner	Sub Contoso-Prod	False
Owner1a	Owner	Sub Contoso-Dev	False
Owner1b	Owner	Sub Contoso-Dev	False
Owner1c	Owner	Sub Contoso-Dev	False
Owner2a	Owner	Sub Contoso-Sandbox	False
Owner2b	Owner	Sub Contoso-Sandbox	False
Owner2c	Owner	Sub Contoso-Sandbox	False

Printed: first 10 of 11 rows. The HTML report lists them all.

Evidence for ALZ checklist item(s): 14658d35

Privileged Identity Management for Azure resourcesALZ design area: identity and access management

● Fail

● High

Custom roles with wildcard or role-assignment permissions

IAM-009

1 custom roles; 1 grant '*' (Owner-equivalent), 0 can write role assignments.

WHY IT MATTERS

A custom role with '*' actions is an unreviewed Owner. Roles that can write role assignments can escalate their own privileges.

RECOMMENDATION

Replace wildcard actions with explicit operations, add NotActions for Microsoft.Authorization/*/write where escalation is not intended, and limit assignable scopes.

Effort: medium · Source: AzGovViz RoleDefinitions

EVIDENCE

ROLE	ASSIGNMENTS	ASSIGNABLE SCOPES	ISSUE
Custom Owner	0	1	'*' actions

Azure custom roles

● Fail

● Medium

Orphaned role assignments (deleted identities)

IAM-003

1 role assignments point to identities that no longer exist.

WHY IT MATTERS

Orphaned assignments clutter access reviews, count against the 4,000 assignments-per-subscription limit and can be confusing during incident response.

RECOMMENDATION

Delete assignments whose principal is 'Identity not found' (Access control (IAM) > Role assignments > filter Unknown) and automate the clean-up after identity deletion.

Effort: low · Source: AzGovViz RoleAssignments

EVIDENCE

OBJECT ID	ROLE	SCOPE
deadbeef	Reader	Sub Contoso-Dev

Troubleshoot Azure RBAC – identity not found

● Fail

● Medium

Number of Owners per subscription

IAM-004

3 of 3 subscriptions have more than 3 Owner principals (direct + inherited).

WHY IT MATTERS

Microsoft recommends at most three Owners per subscription (and more than one to avoid lock-out). Every additional Owner widens the blast radius of a compromised account.

RECOMMENDATION

Keep 2-3 Owners per subscription, preferably a PIM-eligible group; move day-to-day administrators to Contributor or narrower custom roles.

Effort: low · Source: AzGovViz RoleAssignments

EVIDENCE

SUBSCRIPTION	OWNER PRINCIPALS	USERS	GROUPS	SERVICE PRINCIPALS
Contoso-Prod	6	4	0	2
Contoso-Dev	4	4	0	0
Contoso-Sandbox	4	4	0	0

Azure RBAC best practices

● Fail

● Medium

Access granted to individual users instead of groups

IAM-005

14 of 17 role assignments (82.4%) target individual users; 0 target groups.

WHY IT MATTERS

User-by-user assignments do not scale, are hard to review and survive role changes. Group-based access aligns permissions with team membership and enables PIM for groups.

RECOMMENDATION

Create Entra ID groups per role and scope (e.g. 'sub-prod-contributors'), assign roles to the groups and remove direct user assignments.

Effort: medium · Source: AzGovViz RoleAssignments

EVIDENCE

USER	ROLE	SCOPE
Alice Admin	Owner	MG 00000000-1111-2222-3333-444444444444
Owner0a	Owner	Sub Contoso-Prod
Owner0b	Owner	Sub Contoso-Prod
Owner0c	Owner	Sub Contoso-Prod

USER	ROLE	SCOPE
Guest0	Contributor	Sub Contoso-Prod
Owner1a	Owner	Sub Contoso-Dev
Owner1b	Owner	Sub Contoso-Dev
Owner1c	Owner	Sub Contoso-Dev
Guest1	Contributor	Sub Contoso-Dev
Owner2a	Owner	Sub Contoso-Sandbox

Printed: first 10 of 14 rows. The HTML report lists them all.

[Azure RBAC best practices](#) [ALZ design area: identity and access management](#)

Guest accounts with privileged or write access

Warning High 3 guest identities hold Owner/Contributor/User Access Administrator (0 with Owner-level rights). **IAM-001**

WHY IT MATTERS

External identities are governed by another organisation's lifecycle and security controls. Privileged access for guests is a common lateral-movement and data-exfiltration path.

RECOMMENDATION

Remove or downgrade guest privileged assignments; if external admins are required use Azure Lighthouse or PIM-eligible, time-bound assignments with access reviews.

Effort: low · Source: AzGovViz RoleAssignments

EVIDENCE

PRINCIPAL	ROLE	SCOPE	ASSIGNMENT
Guest0	Contributor	Sub Contoso-Prod	direct
Guest1	Contributor	Sub Contoso-Dev	direct
Guest2	Contributor	Sub Contoso-Sandbox	direct

[Restrict guest access permissions](#) [Azure RBAC best practices](#)

Owner-level rights granted to individuals at management-group scope

Warning High 1 Owner/User Access Administrator assignments at management-group scope are held by 1 individual users or service principals (not groups). **IAM-007**

WHY IT MATTERS

Management-group assignments inherit to every child subscription. Individual standing Owners at this level are the highest-value target in the estate.

RECOMMENDATION

Grant management-group Owner only through a small, PIM-eligible platform-admin group; keep break-glass accounts excluded from Conditional Access only as documented.

Effort: medium · Source: AzGovViz RoleAssignments

EVIDENCE

PRINCIPAL	TYPE	ROLE	SCOPE
Alice Admin	User Member	Owner	MG 00000000-1111-2222-3333-444444444444

[ALZ design area: identity and access management](#) [Privileged Identity Management for Azure resources](#)

Warning

Medium

Policy remediation identities with Owner

1 policy-assignment managed identities hold Owner.

IAM-011

WHY IT MATTERS

DeployIfNotExists/Modify assignments need only the roles listed in the policy definition (roleDefinitionIds). Owner on a policy identity is unnecessary privilege.

RECOMMENDATION

Re-create the assignment identities with the minimum roles from the policy definitions.

Effort: low · Source: AzGovViz RoleAssignments

EVIDENCE

IDENTITY	POLICY ASSIGNMENT	SCOPE
policy-mi	/providers/x (Deploy diag)	Sub Contoso-Prod

Azure RBAC best practices

Warning

Low

Classic subscription administrators

1 co-administrators remain on 1 subscriptions.

IAM-010

WHY IT MATTERS

Classic administrator roles were retired on 31 August 2024; leftover entries signal unmanaged legacy access and should be converted to Azure RBAC.

RECOMMENDATION

Remove co-administrators and grant equivalent Azure RBAC roles (prefer groups + PIM).

Effort: low · Source: AzGovViz ClassicAdministrators

EVIDENCE

SUBSCRIPTION	IDENTITY	ROLE
Contoso-Prod	old@contoso.com	CoAdministrator

Azure classic subscription administrators (retired)

Warning

Low

Assessment identity has more than Reader

The identity used for this assessment holds Owner (BuiltInRole) at the assessed management group.

IAM-012

WHY IT MATTERS

Governance tooling only needs Reader. Running it with Owner means a leaked token or a compromised workstation could change the whole estate.

RECOMMENDATION

Run scheduled assessments with a dedicated service principal or managed identity that has Reader (plus the documented Graph permissions) only.

Effort: low · Source: AzGovViz console log

AzGovViz setup guide

Pass

Low

Role assignment sprawl at resource scope

17 unique role assignments: Mg 1, Sub 15, Ten 1.

IAM-013

Pass

Low

Redundant role assignments (already inherited)

No assignment duplicates an inherited one.

IAM-014

● Fail

● Medium

Subscriptions placed directly under the Tenant Root Group

ORG-001

1 of 3 subscriptions sit directly under the Tenant Root Group.

WHY IT MATTERS

Subscriptions under the root inherit only root-level policy and RBAC, cannot be governed by landing-zone archetypes, and signal an unmanaged hierarchy.

RECOMMENDATION

Create an intermediate-root management group with Platform / Landing zones / Sandbox children and move each subscription to the group that matches its workload type.

Effort: low · Source: AzGovViz hierarchy

EVIDENCE

SUBSCRIPTION	ID
Contoso-Sandbox	aaaaaaaa-0000-0000-0000-000000000003

ALZ design area: resource organization (management groups)

● Fail

● Medium

Management group creation requires authorization

ORG-007

Any user can create management groups (RBAC authorization is not required).

WHY IT MATTERS

By default every user can create management groups under the root, bypassing the intended structure and its policy assignments.

RECOMMENDATION

Enable 'Require write permissions for creating new management groups' in hierarchy settings.

Effort: low · Source: ARM hierarchy settings

Evidence for ALZ checklist item(s): 74d00018

Management group hierarchy settings

● Fail

● Medium

Tagging coverage

ORG-008

26.0% of resources (13/50) carry at least one tag; 25.0% of resource groups (3/12).

WHY IT MATTERS

Tags are how cost, ownership and environment are attributed. Untagged resources become unowned spend and slow down incident response.

RECOMMENDATION

Define mandatory tags (owner, costCenter, environment, application), enforce them with policy on resource groups and inherit them to resources.

Effort: medium · Source: Resource Graph

EVIDENCE

RESOURCE TYPE	RESOURCES	TAGGED	COVERAGE %
microsoft.operationalinsights/workspaces	2	0	0.0
microsoft.containerservice/managedclusters	1	0	0.0
microsoft.network/applicationgateways	1	0	0.0
microsoft.web/sites	5	1	20.0
microsoft.compute/disks	8	2	25.0
microsoft.network/virtualnetworks	4	1	25.0
microsoft.network/publicipaddresses	4	1	25.0
microsoft.network/networksecuritygroups	7	2	28.6
microsoft.storage/storageaccounts	9	3	33.3

RESOURCE TYPE	RESOURCES	TAGGED	COVERAGE %
microsoft.compute/virtualmachines	6	2	33.3

Printed: first 10 of 11 rows. The HTML report lists them all.

[Define your tagging strategy](#)

● Fail

● Low

Naming convention (CAF abbreviations)

ORG-010

33.3% of 9 resources with a CAF abbreviation follow it in their name.

WHY IT MATTERS

A consistent naming scheme makes ownership, environment and resource type obvious in logs, bills and alerts.

RECOMMENDATION

Adopt the CAF naming convention (type abbreviation, workload, environment, region, instance) and enforce it in IaC modules.

Effort: high · Source: AzGovViz ResourcesAll

EVIDENCE

RESOURCE TYPE	NAMES NOT FOLLOWING CAF
microsoft.storage/storageaccounts	6

Evidence for ALZ checklist item(s): [cacf55bc](#)

[Abbreviation recommendations for Azure resources](#)

● Warning

● Medium

Platform and landing-zone separation

Platform management group: not found; landing-zone management group(s): found.

ORG-003

WHY IT MATTERS

Separating shared platform services (connectivity, identity, management) from application landing zones lets you apply different policy and access models to each.

RECOMMENDATION

Create 'Platform' (Connectivity, Identity, Management) and 'Landing zones' (Corp, Online) management groups and place subscriptions by purpose.

Effort: medium · Source: AzGovViz hierarchy

Evidence for ALZ checklist item(s): [61623a76](#)

[ALZ design area: resource organization \(management groups\)](#)

● Warning

● Low

Default management group for new subscriptions

New subscriptions land in the Tenant Root Group (default setting).

ORG-006

WHY IT MATTERS

Without a default management group, newly created subscriptions start ungoverned at the root.

RECOMMENDATION

Set a default management group (e.g. a 'Sandbox' or 'Onboarding' group) in Management groups > Settings.

Effort: low · Source: ARM hierarchy settings

[Management group hierarchy settings](#)

● Warning

● Low

Subscription metadata tags

2 of 3 subscriptions have no tags.

ORG-009

WHY IT MATTERS

Subscription tags (owner, cost center, environment, criticality) feed cost reports and landing-zone automation.

RECOMMENDATION

Tag every subscription with owner, cost center, environment and data classification.

Effort: low · Source: AzGovViz / Resource Graph

EVIDENCE

SUBSCRIPTION

Contoso-Dev

Contoso-Sandbox

Define your tagging strategy

● Pass

● Medium

Management group hierarchy beneath the root

3 management groups (including the Tenant Root Group); 2 directly under the Tenant Root Group.

ORG-002

● Pass

● Low

Sandbox management group for experimentation

A sandbox management group exists.

ORG-004

● Pass

● Low

Hierarchy depth

The deepest management group is 1 level(s) below the Tenant Root Group.

ORG-005

Governance & Policy

Azure Policy guardrails, compliance state, exemptions, ALZ policy currency

score 64.3

● Fail

● Medium

Data residency guardrail (allowed locations)

An allowed-locations policy applies to 0 of 3 subscriptions.

GOV-003

WHY IT MATTERS

Without a location guardrail, resources (and data) can be deployed to any Azure region, which can breach data-residency commitments and complicates DR and cost management.

RECOMMENDATION

Assign 'Allowed locations' and 'Allowed locations for resource groups' (Deny) at the intermediate-root management group with your approved regions.

Effort: low · Source: AzGovViz PolicyAssignments

EVIDENCE

SUBSCRIPTION

ALLOWED LOCATIONS ENFORCED

Contoso-Dev

no

Contoso-Prod

no

Contoso-Sandbox

no

Evidence for ALZ checklist item(s): 5a917e1f

Allowed locations built-in policy

● Fail

● Medium

Policy compliance state

22 of 50 evaluated resources (44.0%) are non-compliant with at least one assigned policy.

GOV-015

WHY IT MATTERS

Non-compliance shows where existing guardrails are already being violated; it is the backlog for remediation and exemption decisions.

RECOMMENDATION

Triage non-compliance by initiative: remediate, exempt with expiry, or adjust the policy.

EVIDENCE

MEASURE	VALUE
Resources with a policy state	50
Non-compliant (at least one policy)	22
Compliant with every policy	28
Policy evaluations	160

[Get compliance data](#)

Security baseline initiative (Microsoft cloud security benchmark)

WarningHigh

Microsoft cloud security benchmark applies to 2 of 3 subscriptions. Missing: Contoso-Sandbox.

GOV-002

WHY IT MATTERS

The MCSB initiative powers Defender for Cloud recommendations and the secure score. Without it, security posture is not continuously evaluated.

RECOMMENDATION

Assign the 'Microsoft cloud security benchmark' initiative at the intermediate-root management group (Defender for Cloud does this per subscription by default).

Effort: low · Source: AzGovViz PolicyAssignments

EVIDENCE

SUBSCRIPTION	MCSB APPLIED
Contoso-Dev	yes
Contoso-Prod	yes
Contoso-Sandbox	no

[Microsoft cloud security benchmark](#)

Policy assignments not enforced (DoNotEnforce)

WarningMedium

1 policy assignments run in DoNotEnforce mode (evaluated but not enforced).

GOV-004

WHY IT MATTERS

DoNotEnforce is useful for what-if testing, but left in place it silently disables Deny and DeployIfNotExists effects.

RECOMMENDATION

Review each DoNotEnforce assignment: enforce it, or delete it if it is no longer needed.

Effort: low · Source: AzGovViz PolicyAssignments

EVIDENCE

ASSIGNMENT	SCOPE	POLICY
Allowed locations	Contoso-Prod	Allowed locations

[Enforcement mode](#)

Preventive (Deny) guardrails

Warning

Medium

0 enforced single-policy assignments use Deny; 1 enforced initiatives assigned (initiative effects are evaluated per member policy). **GOV-005**

WHY IT MATTERS

Audit-only policy reports problems after they happen. Deny guardrails (locations, public network access, SKU restrictions) stop misconfiguration at deployment time.

Evidence for ALZ checklist item(s): a6e55d7d

ALZ design area: governance (Azure Policy)

RECOMMENDATION

Introduce Deny policies for the highest-risk configurations (public IPs on NICs, storage public access, allowed locations) after an audit period.

Effort: medium · Source: AzGovViz PolicyAssignments

Control of which services can be deployed

Warning

Low

No allowed/not-allowed resource type policy is assigned.

GOV-008

WHY IT MATTERS

Restricting resource types keeps unapproved or unsupported services out of landing zones.

Evidence for ALZ checklist item(s): 43334f24

ALZ design area: governance (Azure Policy)

RECOMMENDATION

Assign 'Not allowed resource types' for services you do not support (e.g. classic resources).

Effort: low · Source: AzGovViz PolicyAssignments

Tag governance policies

Warning

Low

No tag governance policies are assigned.

GOV-009

WHY IT MATTERS

Tags such as owner, cost center and environment drive cost allocation, automation and incident routing; without policy they decay quickly.

Tag policies

RECOMMENDATION

Assign 'Require a tag on resource groups' and 'Inherit a tag from the resource group' for your mandatory tags.

Effort: low · Source: AzGovViz PolicyAssignments

Warning

Low

Policy exemptions are time-bound

GOV-011

1 exemptions: 1 never expire, 0 already expired.

WHY IT MATTERS

Exemptions without expiry turn temporary waivers into permanent gaps.

RECOMMENDATION

Set an expiry and a 'Mitigated'/'Waiver' category with justification on every exemption; remove expired exemptions.

Effort: low · Source: AzGovViz PolicyExemptions

EVIDENCE

EXEMPTION	SCOPE	CATEGORY	EXPIRES
legacy-app	Sub	Waiver	n/a

Azure Policy exemption structure

Warning

Low

Custom policy hygiene

1 custom policies (1 unused), 0 custom initiatives (0 unassigned), 0 duplicate a built-in definition. GOV-012

WHY IT MATTERS

Unused and duplicate custom definitions add maintenance burden and confuse authors.

RECOMMENDATION

Delete unused custom definitions and replace duplicates with the equivalent built-in.

Effort: low · Source: AzGovViz PolicyDefinitions

EVIDENCE

DEFINITION	KIND	SCOPE	ISSUE
Old custom	policy	00000000-1111-2222-3333-444444444444	unused

ALZ design area: governance (Azure Policy)

Warning

Low

Pending DeployIfNotExists / Modify remediation

7 non-compliant resources could be fixed by remediation tasks across 1 policies. GOV-014

WHY IT MATTERS

DINE/Modify policies only fix existing resources when a remediation task runs.

RECOMMENDATION

Create remediation tasks for these assignments (portal: Policy > Remediation) and keep the assignment identities least-privileged.

Effort: low · Source: AzGovViz PolicyRemediation

EVIDENCE

ASSIGNMENT	POLICY	EFFECT	RESOURCES
Deploy diag	Diag to LA	deployIfNotExists	7

Remediate non-compliant resources

Warning

Low

Custom definitions stored at management-group scope

1 of 1 custom policy/initiative definitions are stored at management-group scope (1 at the Tenant Root Group, 0 at subscription scope). GOV-016

WHY IT MATTERS

Definitions stored on a subscription can only be assigned there; storing them at the intermediate root makes them reusable across the hierarchy.

RECOMMENDATION

Store custom definitions at the intermediate-root management group (not the Tenant Root Group or individual subscriptions) and manage them as code.

Effort: medium · Source: AzGovViz PolicyDefinitions

EVIDENCE

DEFINITION	SCOPE	SCOPE ID
Old custom	Tenant Root Group	00000000-1111-2222-3333-444444444444

Evidence for ALZ checklist item(s): 223ace8c

ALZ design area: governance (Azure Policy)

● Pass

● High

Policy guardrails assigned at management-group scope

1 of 2 policy assignments are made at management-group scope (subscription 1, resource group 0).

GOV-001

● Pass

● Low

Policy strategy: initiatives and built-in definitions

1 initiative assignments; 0 of 2 assignments use custom definitions.

GOV-006

● Pass

● Low

Assignments at the Tenant Root Group

0 policy assignments are made directly at the Tenant Root Group.

GOV-007

Security

Defender for Cloud coverage, secure configuration, data exposure

score 41.1

● Fail

● High

Defender workload protection for deployed services

0 of 1 relevant plan/subscription combinations are protected (1 gaps across 1 plans).

SEC-003

WHY IT MATTERS

Workload plans detect threats specific to storage (malware upload, anomalous access), Key Vault, SQL, containers, App Service and Resource Manager operations.

RECOMMENDATION

Enable the Defender plans that match deployed services; Resource Manager and Key Vault plans are low-cost and protect the control plane.

Effort: low · Source: Resource Graph securityresources

EVIDENCE

PLAN	SUBSCRIPTIONS WITH WORKLOAD	PROTECTED	UNPROTECTED (SAMPLE)
Storage	1	0	Contoso-Prod

Evidence for ALZ checklist item(s): 77425f48

Defender for Cloud plans

● Fail

● High

Anonymous (public) blob access

1 storage accounts expose containers anonymously; 3 of 9 storage accounts allow anonymous blob access to be enabled.

SEC-008

WHY IT MATTERS

Anonymous containers are readable by anyone on the internet who guesses the URL - a frequent cause of data leaks.

RECOMMENDATION

Set 'Allow Blob anonymous access' to Disabled on every account (policy: 'Storage account public access should be disallowed', Deny) and use SAS/Entra ID for

sharing.

Effort: low · Source: Resource Graph / AzGovViz
StorageAccountAccessAnalysis

EVIDENCE

STORAGE ACCOUNT	SUBSCRIPTION	ANONYMOUS CONTAINERS/BLOBS	STATIC WEBSITE
st0	Contoso-Prod	1	false

Prevent anonymous read access to blobs

● Fail

● Medium

Defender for Cloud secure score

SEC-006

Average secure score 46.0% across 3 subscriptions (lowest 36.0%).

WHY IT MATTERS

The secure score aggregates the Microsoft cloud security benchmark recommendations; each point represents a closed attack surface.

RECOMMENDATION

Work the recommendations with the highest score impact first; assign owners and due dates with Defender for Cloud governance rules.

Effort: medium · Source: Resource Graph securityresources

EVIDENCE

SUBSCRIPTION	SCORE %	POINTS
Contoso-Prod	36.0	18.0 / 50.0
Contoso-Dev	46.0	23.0 / 50.0
Contoso-Sandbox	56.0	28.0 / 50.0

Secure score

● Fail

● Medium

Storage accounts accepting HTTP or TLS < 1.2

SEC-009

3 of 9 storage accounts allow HTTP or TLS 1.0/1.1.

WHY IT MATTERS

Legacy TLS versions are deprecated (Azure Storage retires TLS 1.0/1.1) and HTTP exposes data and keys in transit.

RECOMMENDATION

Set 'Secure transfer required' and minimum TLS 1.2 on all accounts and enforce with policy.

Effort: low · Source: Resource Graph

EVIDENCE

STORAGE ACCOUNT	HTTPS ONLY	MINIMUM TLS
st0	True	TLS1_0
st3	True	TLS1_0
st6	True	TLS1_0

Evidence for ALZ checklist item(s): b03ed428

Enforce a minimum TLS version for storage

● Fail

● Medium

Data stores reachable from all networks

SEC-010

9 of 9 storage accounts and 3 of 3 key vaults accept traffic from any network.

WHY IT MATTERS

Public endpoints rely solely on identity controls. Private endpoints or firewall rules add a network boundary and stop credential-stuffing and token replay from the internet.

RECOMMENDATION

Use private endpoints (or at least firewall + trusted services) for storage and Key Vault; set publicNetworkAccess to Disabled where possible.

Effort: medium · Source: Resource Graph

EVIDENCE

RESOURCE	TYPE	PUBLIC NETWORK ACCESS
st0	storage	Enabled / default Allow
st1	storage	Enabled / default Allow
st2	storage	Enabled / default Allow
st3	storage	Enabled / default Allow
st4	storage	Enabled / default Allow
st5	storage	Enabled / default Allow
st6	storage	Enabled / default Allow
st7	storage	Enabled / default Allow
st8	storage	Enabled / default Allow
kv0	key vault	Enabled

Printed: first 10 of 12 rows. The HTML report lists them all.

Evidence for ALZ checklist item(s): cdb3751a

Configure Azure Storage firewalls and virtual networks

Warning

High

Defender Cloud Security Posture Management (CSPM)

SEC-001

Defender CSPM is enabled on 1 of 3 subscriptions.

WHY IT MATTERS

Foundational CSPM only gives the secure score. Defender CSPM adds attack-path analysis, the cloud security explorer, agentless scanning and governance rules.

RECOMMENDATION

Enable Defender CSPM on all subscriptions (assign the Defender for Cloud plan policies at the intermediate-root management group).

Effort: low · Source: Resource Graph securityresources

EVIDENCE

SUBSCRIPTION	DEFENDER CSPM
Contoso-Dev	off
Contoso-Prod	off
Contoso-Sandbox	on

Evidence for ALZ checklist item(s): 09945bda

Defender CSPM

Warning

High

Open high-severity Defender for Cloud recommendations

1 high-severity recommendations are open on 2 resources (2 recommendations open in total). SEC-007

WHY IT MATTERS

High-severity recommendations map to directly exploitable weaknesses (e.g. missing MFA for owners, internet-exposed management ports, vulnerable software).

RECOMMENDATION

Remediate high-severity recommendations first; use 'Fix' or policy-driven remediation and track progress in the secure score.

Effort: medium · Source: Resource Graph securityresources

EVIDENCE

RECOMMENDATION	SEVERITY	UNHEALTHY RESOURCES
Storage accounts should restrict network access	Medium	6
MFA should be enabled on accounts with owner permissions	High	2

Secure score

Warning

Medium

Defender for Resource Manager (control-plane threat detection)

SEC-004

Defender for Resource Manager is on for 1 of 3 subscriptions.

WHY IT MATTERS

Detects suspicious management operations (e.g. mass deletion, unusual role assignment, operations from malicious IPs) across every resource in the subscription.

RECOMMENDATION

Enable Defender for Resource Manager on every subscription.

Effort: low · Source: Resource Graph securityresources

Defender for Cloud plans

Warning

Medium

Security alert contacts and notifications

SEC-005

1 of 3 subscriptions send Defender for Cloud alerts to a security contact.

WHY IT MATTERS

High-severity alerts are only useful if someone receives them; by default only subscription owners may be notified.

RECOMMENDATION

Configure a security operations distribution list as security contact with alert notifications on (minimum severity: Medium) on every subscription - via policy at scale.

Effort: low · Source: ARM securityContacts

EVIDENCE

SUBSCRIPTION	CONTACT CONFIGURED
Contoso-Prod	yes
Contoso-Dev	no
Contoso-Sandbox	no

Configure email notifications for alerts

Warning

Medium

Key Vault purge protection

SEC-011

2 of 3 key vaults have purge protection disabled.

WHY IT MATTERS

Without purge protection a malicious or accidental purge permanently destroys keys, secrets and certificates - including keys used for encryption at rest.

RECOMMENDATION

Enable purge protection (irreversible by design) on all production key vaults.

Effort: low · Source: Resource Graph

EVIDENCE

KEY VAULT	SOFT DELETE	PURGE PROTECTION
kv0	True	True
kv1	True	False
kv2	True	False

Evidence for ALZ checklist item(s): 2ba52752

Key Vault soft-delete and purge protection

Warning

Low

Key Vault permission model

SEC-012

1 of 3 key vaults still use access policies instead of Azure RBAC.

WHY IT MATTERS

Access policies cannot be governed with PIM, conditional role assignment or management-group scoped reviews; Azure RBAC can.

RECOMMENDATION

Migrate key vaults to the Azure RBAC permission model.

Effort: medium · Source: Resource Graph

EVIDENCE

KEY VAULT
kv2

Evidence for ALZ checklist item(s): d4d1ad54

Key Vault Azure RBAC permission model

Network Topology, segmentation, private connectivity, internet exposure

score 45.4

Fail

High

Management ports (SSH/RDP) open to the internet

NET-001

1 NSG rules allow inbound SSH/RDP (or any port) from the internet across 1 NSGs.

WHY IT MATTERS

Internet-exposed management ports are brute-forced within minutes of exposure and are a top initial-access vector for ransomware.

RECOMMENDATION

Remove the rules; use Azure Bastion or Defender for Servers just-in-time VM access, and deny inbound management ports from the internet with policy.

Effort: low · Source: Resource Graph

EVIDENCE

NSG	RULE	PORT(S)	SOURCE	SUBSCRIPTION
nsg-jump	allow-rdp	3389	*	Contoso-Sandbox

Network security best practices

Azure Bastion

Warning

Medium

Subnets without a network security group

NET-003

1 of 3 subnets (excluding gateway/firewall/bastion subnets) have no NSG.

WHY IT MATTERS

Subnets without NSGs allow unrestricted east-west traffic, so one compromised workload can reach every other.

RECOMMENDATION

Associate an NSG with every workload subnet (policy: 'Subnets should be associated with a Network Security Group').

EVIDENCE

SUBNET	VNET	SUBSCRIPTION	PREFIX
data	vnet-spoke2		10.2.0.0/28

Network security best practices

Warning

Low

Subnet IP address capacity
1 subnets are above the IP usage threshold.

NET-004

WHY IT MATTERS

Exhausted subnets block scale-out, upgrades and new private endpoints.

RECOMMENDATION

Plan larger address spaces or add subnets before scale events; keep 20%+ headroom.

Effort: medium · Source: AzGovViz VirtualNetworkSubnets

EVIDENCE

SUBNET	VNET	USED %	AVAILABLE IPS
data	vnet-spoke2	91 %	

ALZ design area: network topology and connectivity

Warning

Low

Private connectivity for PaaS services
1 private endpoints in the estate; 1 connect storage accounts/key vaults (out of 12).

NET-005

WHY IT MATTERS

Private endpoints keep data-plane traffic on the Microsoft backbone and allow disabling public network access entirely.

RECOMMENDATION

Use private endpoints with centralised private DNS zones (policy-driven) for data services.

Effort: medium · Source: AzGovViz PrivateEndpoints

EVIDENCE

PRIVATE_ENDPOINT	TARGET_TYPE	TARGET	SUBSCRIPTION
pe-kv0	microsoft.keyvault/vaults	kv0	Contoso-Prod

Azure Private Link and private endpoints

Info

Low

DDoS protection for internet-facing workloads
4 public IP addresses; 0 of 4 VNets have DDoS Network Protection.

NET-006

Pass

Medium

Network topology (hub-and-spoke / Virtual WAN)
Hub-and-spoke pattern detected: 1 hub VNet(s) (vnet-hub); 1 of 4 VNets are not peered.

NET-002

Management & Monitoring

Logging, alerting, diagnostics, resource locks, backup

score 55.3

Warning

Medium

Subscription activity logs exported
1 of 3 subscriptions export the activity log (diagnostic settings).

MGT-001

WHY IT MATTERS

The activity log is the audit trail of every control-plane change. It is kept for only 90 days and cannot be correlated with other signals unless exported.

RECOMMENDATION

Send every subscription's activity log to the central Log Analytics workspace (policy: 'Configure Azure Activity logs to stream to specified Log Analytics workspace').

Effort: low · Source: ARM diagnosticSettings

EVIDENCE

SUBSCRIPTION	EXPORTED	DESTINATION
Contoso-Prod	yes	x
Contoso-Dev	no	
Contoso-Sandbox	no	

Evidence for ALZ checklist item(s): 4e3ab369

Create diagnostic settings for the activity log

Warning

Medium

Service Health and Resource Health alerts

MGT-003

1 of 3 subscriptions have Service Health alerts; 0 have Resource Health alerts.

WHY IT MATTERS

Service Health alerts tell you about Azure incidents, planned maintenance and retirements affecting your resources before users do.

RECOMMENDATION

Deploy Service Health and Resource Health activity-log alerts with action groups on every subscription (Azure Monitor Baseline Alerts for ALZ automates this).

Effort: low · Source: Resource Graph

EVIDENCE

SUBSCRIPTION	SERVICE HEALTH	RESOURCE HEALTH
Contoso-Dev	no	no
Contoso-Prod	yes	no
Contoso-Sandbox	no	no

Evidence for ALZ checklist item(s): d5f345bf , e5695f22

Create Service Health alerts

Azure Monitor Baseline Alerts (AMBA) for ALZ

Warning

Low

Resource locks on critical resources

MGT-004

No resource locks found.

WHY IT MATTERS

Locks prevent accidental deletion of shared platform resources (hub networks, DNS zones, Log Analytics, Key Vaults) even by Owners.

RECOMMENDATION

Apply CannotDelete locks to shared platform resource groups and protect them with policy.

Effort: low · Source: AzGovViz ResourceLocks

Evidence for ALZ checklist item(s): 541acdce

Lock your resources

Pass

Medium

Centralised Log Analytics

MGT-002

1 Log Analytics workspace(s) across 1 subscription(s).

Warning

Medium

Budgets with alerts on every subscription

1 of 3 subscriptions have a budget; 0 with alert notifications.

CST-001

WHY IT MATTERS

Budgets with actual and forecast alerts are the cheapest control against runaway spend (e.g. forgotten GPU VMs or a misconfigured autoscale).

RECOMMENDATION

Create a monthly budget with 80%/100% actual and 110% forecast alerts per subscription (deploy with policy or IaC during subscription vending).

Effort: low · Source: ARM Consumption budgets

EVIDENCE

SUBSCRIPTION	BUDGETS	AMOUNT	NOTIFICATIONS
Contoso-Prod	1	500	0
Contoso-Dev	0	-	0
Contoso-Sandbox	0	-	0

Evidence for ALZ checklist item(s): 29fd366b

Create and manage budgets

Warning

Medium

Orphaned and idle resources

2 orphaned/idle resources: cost savings 1, clean up 1.

CST-002

WHY IT MATTERS

Unattached disks, idle public IPs, empty App Service plans and stopped-but-allocated VMs cost money, and orphaned NICs/NSGs/route tables add configuration noise and attack surface.

RECOMMENDATION

Review the list with owners, delete what is unused and add a monthly clean-up (Azure Orphaned Resources workbook or automation).

Effort: low · Source: AzGovViz ResourcesCostOptimizationAndCleanup

EVIDENCE

TYPE	RESOURCE	INTENT	SUBSCRIPTION
microsoft.compute/disks	rg/d1	cost savings	Contoso-Dev
microsoft.resources/subscriptions/resourcegroups	empty/empty	clean up	Contoso-Sandbox

Azure Orphaned Resources workbook

Warning

Low

Azure Advisor cost recommendations

2 resources have open Advisor cost recommendations (1 distinct recommendations).

CST-003

WHY IT MATTERS

Advisor identifies right-sizing, reservations, savings plans and idle resources from actual usage.

RECOMMENDATION

Review Advisor cost recommendations monthly; buy reservations/savings plans for steady workloads.

Effort: low · Source: Resource Graph advisorresources

EVIDENCE

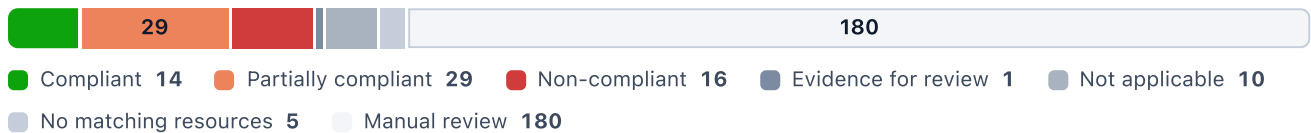
RECOMMENDATION	IMPACT	RESOURCES
Right-size underutilized VMs	Medium	2

6 Azure review checklists

Recommendations from Azure/review-checklists (commit `f131b93`), evaluated with their Azure Resource Graph queries against this tenant. Items without a query need a reviewer; several are answered by tenant evidence from the findings above. Results per checklist are also saved in the official `checklist_graph.sh` format for the review-checklists Excel workbook: `alz · waf · aprl`.

Azure Landing Zone (ALZ) Review GA FEBRUARY 25, 2026 49.7% items passing

255 items · 49 with Resource Graph queries · 59 evaluated against resources · resource-level compliance 56.9% (62 of 109 resource checks)



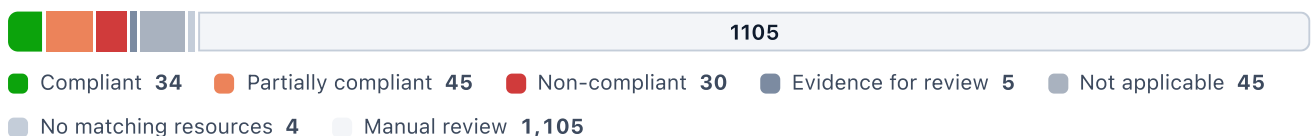
26 otherwise-manual items were assessed with tenant evidence (marked **via finding**).

▼ Results by category

Category	Items	Evaluated	Status Mix
Network Topology and Connectivity	106	26	
Security	32	8	
Management	26	6	
Identity and Access Management	24	5	
Resource Organization	22	6	
Governance	16	8	
Azure Billing and Microsoft Entra ID Tenants	15	0	
Platform Automation and DevOps	14	0	

Well-Architected Framework (WAF) Review APRIL 16, 2025 53.2 % items passing

1,268 items · 149 with Resource Graph queries · 109 evaluated against resources · resource-level compliance 57.2% (163 of 285 resource checks)



14 otherwise-manual items were assessed with tenant evidence (marked **via finding**).

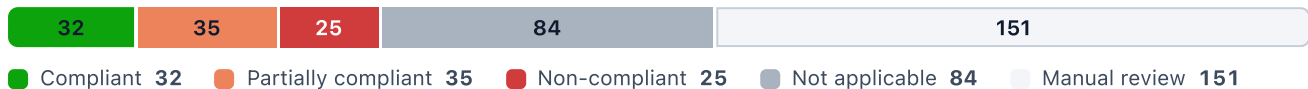
▼ Results by category

Category	Items	Evaluated	Status Mix
Security	553	63	
Reliability	337	27	
Operations	197	11	
Cost	94	2	
Performance	86	6	
Governance	1	0	

Azure Proactive Resiliency Library (APRL) PREVIEW JULY 14, 2024

57.4 % items passing

327 items · 176 with Resource Graph queries · 92 evaluated against resources · resource-level compliance 68% (232 of 341 resource checks)



▼ Results by category

CATEGORY	ITEMS	EVALUATED	STATUS MIX
High Availability	109	26	
Monitoring and Alerting	54	9	
Scalability	48	16	
Disaster Recovery	38	10	
Security	31	16	
Governance	29	7	
Other Best Practices	10	7	
Business Continuity	4	0	
Personalized	2	0	
Service Upgrade and Retirement	2	1	

All checklist items

Manual-review items are listed for the ALZ checklist only; 1,105 manual items of Well-Architected Framework (WAF) Review are in checklists/results.json; 151 manual items of Azure Proactive Resiliency Library (APRL) are in checklists/results.json.

This printout lists 180 of 594 items (the filter that was active in the report). The full list is in the HTML report and checklists/results.json.

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
Non-compliant	High	Use Standard Load Balancer SKU with a zone-redundant deployment, Selecting Standard SKU Load Balancer enhances reliability through availability zones and zone resiliency, ensuring deployments withstand zone and region failures. Unlike Basic, it supports global load balancing and offers an SLA. ALZ · D01.14 · Network Topology and Connectivity · Hub and spoke	1 × / 0 ✓
Non-compliant	High	Ensure load balancer backend pool(s) contains at least two instances, Deploying Azure Load Balancers with at least two instances in the backend prevents a single point of failure and supports scalability. ALZ · D01.15 · Network Topology and Connectivity · Hub and spoke	1 × / 0 ✓
Non-compliant	High	Configure DDoS Protection on the Azure Firewall VNet, Associate a DDoS protection plan with the virtual network hosting Azure Firewall to provide enhanced mitigation against DDoS attacks. Azure Firewall Manager integrates the creation of firewall infrastructure and DDoS protection plans. ALZ · D07.22 · Network Topology and Connectivity · Firewall	2 × / 0 ✓
Non-compliant	High	Ensure that storage accounts are zone or region redundant, Redundancy ensures storage accounts meet availability and durability targets amidst failures, weighing lower costs against higher availability. Locally redundant storage offers the least durability at the lowest cost. ALZ · F01.18 · Management · Data Protection	2 × / 0 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Non-compliant via finding	● High	Enable Defender Cloud Workload Protection Plans for Azure Resources on all subscriptions. ALZ · G03.05 · Security · Operations	
● Non-compliant via finding	● High	Enable secure transfer to storage accounts. ALZ · G04.01 · Security · Overview	
● Non-compliant	● High	Use replica sets for resiliency or geolocation in Microsoft Entra Domain Services APRL · a3058909 · High Availability · Microsoft.AAD/domainServices	1 × / 0 ✓
● Non-compliant	● High	Migrate API Management services to Premium SKU to support Availability Zones APRL · baf3bfc0 · High Availability · Microsoft.ApiManagement/service	2 × / 0 ✓
● Non-compliant	● High	Configure VMSS Autoscale to custom and configure the scaling metrics APRL · ee66ff65 · Scalability · Microsoft.Compute/virtualMachineScaleSets	3 × / 0 ✓
● Non-compliant	● High	Disable Force strictly even balance across zones to avoid scale in and out fail attempts APRL · b5a63aa0 · High Availability · Microsoft.Compute/virtualMachineScaleSets	3 × / 0 ✓
● Non-compliant	● High	Deploy VMSS across availability zones with VMSS Flex APRL · 1422c567 · High Availability · Microsoft.Compute/virtualMachineScaleSets	2 × / 0 ✓
● Non-compliant	● High	Deploy AKS cluster across availability zones APRL · 4f63619f · High Availability · Microsoft.ContainerService/managedClusters	1 × / 0 ✓
● Non-compliant	● High	Isolate system and application pods APRL · 5ee083cd · High Availability · Microsoft.ContainerService/managedClusters	1 × / 0 ✓
● Non-compliant	● High	Configure user nodepool count APRL · 005ccbbd · High Availability · Microsoft.ContainerService/managedClusters	1 × / 0 ✓
● Non-compliant	● High	Use Azure Linux for Linux nodepools APRL · f46b0d1d · High Availability · Microsoft.ContainerService/managedClusters	1 × / 0 ✓
● Non-compliant	● High	Enable custom maintenance schedule APRL · b2bad57d · Scalability · Microsoft.DBforPostgreSQL/flexibleServers	2 × / 0 ✓
● Non-compliant	● High	Use standard network features for production in Azure NetApp Files APRL · ab984130 · Scalability · Microsoft.NetApp/netAppAccounts	1 × / 0 ✓
● Non-compliant	● High	Enable backup for data protection in Azure NetApp Files APRL · b2fb3e60 · Disaster Recovery · Microsoft.NetApp/netAppAccounts	2 × / 0 ✓
● Non-compliant	● High	Deploy Application Gateway in a zone-redundant configuration APRL · c9c00f2a · High Availability · Microsoft.Network/applicationGateways	1 × / 0 ✓
● Non-compliant	● High	Ensure Application Gateway Subnet is using a /24 subnet mask APRL · 8364fd0a · Other Best Practices · Microsoft.Network/applicationGateways	1 × / 0 ✓
● Non-compliant	● High	Ensure Standard Load Balancer is zone-redundant APRL · 621dbc78 · High Availability · Microsoft.Network/loadBalancers	1 × / 0 ✓
● Non-compliant	● High	Validate VM functionality with a Site Recovery test failover to check performance at target APRL · 17e877f7 · Disaster Recovery · Microsoft.RecoveryServices/vaults	1 × / 0 ✓
● Non-compliant	● High	Use Active Geo Replication to Create a Readable Secondary in Another Region APRL · 74c2491d · Disaster Recovery · Microsoft.Sql/servers	1 × / 0 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Non-compliant	● High	Choose the best CNI network plugin for your requirements (Azure CNI recommended) WAF · a0f61565 · Reliability · Azure AKS Review	1 × / 0 ✓
● Non-compliant	● High	Use private clusters if your requirements mandate it WAF · ecccc979 · Security · Azure AKS Review	1 × / 0 ✓
● Non-compliant	● High	Enable a Kubernetes Network Policy option (Calico/Azure) WAF · 58d7c892 · Security · Azure AKS Review	1 × / 0 ✓
● Non-compliant	● High	Ensure that APIs and endpoints used by the LLM application are properly secured with authentication and authorization mechanisms, such as Managed identities, API keys or OAuth, to prevent unauthorized access. WAF · 1102cac6 · Security · AI Landing Zone	2 × / 0 ✓
● Non-compliant	● High	Use Standard Load Balancer SKU with a zone-redundant deployment, Selecting Standard SKU Load Balancer enhances reliability through availability zones and zone resiliency, ensuring deployments withstand zone and region failures. Unlike Basic, it supports global load balancing and offers an SLA. WAF · 9dcd6250 · Reliability · Azure Landing Zone Review	1 × / 0 ✓
● Non-compliant	● High	Ensure load balancer backend pool(s) contains at least two instances, Deploying Azure Load Balancers with at least two instances in the backend prevents a single point of failure and supports scalability. WAF · 48682fb1 · Reliability · Azure Landing Zone Review	1 × / 0 ✓
● Non-compliant	● High	Configure DDoS Protection on the Azure Firewall VNet, Associate a DDoS protection plan with the virtual network hosting Azure Firewall to provide enhanced mitigation against DDoS attacks. Azure Firewall Manager integrates the creation of firewall infrastructure and DDoS protection plans. WAF · e8143efa · Reliability · Azure Landing Zone Review	2 × / 0 ✓
● Non-compliant via finding	● High	Enable Defender Cloud Workload Protection Plans for Azure Resources on all subscriptions. WAF · 77425f48 · Security · Azure Landing Zone Review	
● Non-compliant via finding	● High	Enable secure transfer to storage accounts. WAF · b03ed428 · Security · Azure Landing Zone Review	
● Non-compliant	● High	Create warning alerts for critical thresholds for automatic alerting on Azure VMware Solution performance (CPU >80%, Avg Memory >80%, vSAN >70%) WAF · 6b84ee5d · Operations · Azure VMware Solution Design Review	2 × / 0 ✓
● Non-compliant	● High	Ensure critical alert is created to monitor if vSAN consumption is below 75% as this is a support threshold from VMware WAF · 9659e396 · Operations · Azure VMware Solution Design Review	2 × / 0 ✓
● Non-compliant via finding	● Medium	Enforce Microsoft Entra ID Privileged Identity Management (PIM) to establish zero standing access and least privilege. ALZ · B03.07 · Identity and Access Management · Identity	
● Non-compliant via finding	● Medium	Use a well defined naming scheme for resources, such as Microsoft Best Practice Naming Standards. ALZ · C01.01 · Resource Organization · Naming and tagging	
● Non-compliant via finding	● Medium	Enforce that only privileged users can operate management groups in the tenant by enabling Azure RBAC authorization in the management group hierarchy settings. ALZ · C02.06 · Resource Organization · Subscriptions	
● Non-compliant	● Medium	Ensure tags are used for billing and cost management. ALZ · C02.14 · Resource Organization · Subscriptions	2 × / 0 ✓
● Non-compliant	● Medium	Use Azure Bastion in a subnet /26 or larger. ALZ · D05.02 · Network Topology and Connectivity · Internet	4 × / 0 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Non-compliant	● Medium	Deploy a zone-redundant ExpressRoute gateway in the supported Azure regions. ALZ · D06.06 · Network Topology and Connectivity · Hybrid	2 × / 0 ✓
● Non-compliant	● Medium	Enable Azure Firewall DNS proxy configuration. ALZ · D07.18 · Network Topology and Connectivity · Firewall	2 × / 0 ✓
● Non-compliant	● Medium	Do not disable branch-to-branch traffic in Virtual WAN, unless these flows should be explicitly blocked. ALZ · D10.06 · Network Topology and Connectivity · Virtual WAN	2 × / 0 ✓
● Non-compliant via finding	● Medium	If any data sovereignty requirements exist, Azure Policies should be deployed to enforce them. ALZ · E03.01 · Governance · Sovereign Cloud	
● Non-compliant via finding	● Medium	Enable private endpoints to control access to the key vault, configure service endpoints and the vault firewall if private endpoints are not applicable ALZ · G02.07 · Security · Encryption and keys	
● Non-compliant	● Medium	Configure Private Endpoints APRL · c474fc96 · Security · Microsoft.Cache/redis	2 × / 0 ✓
● Non-compliant	● Medium	Deploy VMSS with Flex orchestration mode instead of Uniform APRL · e7495e1c · Scalability · Microsoft.Compute/virtualMachineScaleSets	1 × / 0 ✓
● Non-compliant	● Medium	Enable Azure Virtual Machine Scale Set Application Health Monitoring APRL · 94794d2a · Monitoring and Alerting · Microsoft.Compute/virtualMachineScaleSets	1 × / 0 ✓
● Non-compliant	● Medium	Avoid scaling up or down APRL · 07243659 · Scalability · Microsoft.Web/serverFarms	2 × / 0 ✓
● Non-compliant	● Medium	If using a public API endpoint, restrict the IP addresses that can access it WAF · c4581559 · Security · Azure AKS Review	1 × / 0 ✓
● Non-compliant	● Medium	For Windows 2019 and 2022 AKS nodes Calico Network Policies can be used WAF · ce7f2a7c · Security · Azure AKS Review	1 × / 0 ✓
● Non-compliant	● Medium	Ensure you are using the Standard SKU for your Azure Load Balancers WAF · 4e35fbf5 · Security · Azure Application Delivery Networking	2 × / 0 ✓
● Non-compliant	● Medium	Configure autoscaling with a minimum amount of instances of two. WAF · 135bf4ac · Reliability · Azure Application Delivery Networking	1 × / 0 ✓
● Non-compliant	● Medium	Deploy both VMs in the high-availability pair in an availability set or in availability zones. These VMs should be the same size and have the same storage configuration. WAF · f656e745 · Reliability · SAP Checklist	2 × / 0 ✓
● Non-compliant	● Medium	Leverage Azure resource tag for cost categorization and resource grouping (: BillTo, Department (or Business Unit), Environment (Production, Stage, Development), Tier (Web Tier, Application Tier), Application Owner, ProjectName) WAF · 4e138115 · Operations · SAP Checklist	2 × / 0 ✓
● Non-compliant	● Medium	Azure tagging can be leveraged to logically group and track resources, automate their deployments, and most importantly, provide visibility on the incurred costs. WAF · 579266bc · Operations · SAP Checklist	2 × / 0 ✓
● Non-compliant	● Medium	Use Azure Firewall to govern Azure outbound traffic to the internet, non-HTTP/S inbound connections, and East/West traffic filtering (if the organization requires it) WAF · d8a03e97 · Security · SAP Checklist	2 × / 0 ✓
● Non-compliant	● Medium	Use HTTP to HTTPS redirection with Azure Front Door. Support older clients by redirecting them to an HTTPS request automatically. WAF · 10aa45af · Security · Azure Application Delivery Networking	2 × / 0 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Non-compliant via finding	● Medium	Enforce Microsoft Entra ID Privileged Identity Management (PIM) to establish zero standing access and least privilege. WAF · 14658d35 · Security · Azure Landing Zone Review	
● Non-compliant	● Medium	Use Azure Bastion in a subnet /26 or larger. WAF · 6eab9eb6 · Security · Azure Landing Zone Review	4 × / 0 ✓
● Non-compliant	● Medium	Deploy a zone-redundant ExpressRoute gateway in the supported Azure regions. WAF · 2447ec66 · Reliability · Azure Landing Zone Review	2 × / 0 ✓
● Non-compliant	● Medium	Enable Azure Firewall DNS proxy configuration. WAF · 94f3eede · Security · Azure Landing Zone Review	2 × / 0 ✓
● Non-compliant	● Medium	Do not disable branch-to-branch traffic in Virtual WAN, unless these flows should be explicitly blocked. WAF · 727c77e1 · Reliability · Azure Landing Zone Review	2 × / 0 ✓
● Non-compliant via finding	● Medium	If any data sovereignty requirements exist, Azure Policies should be deployed to enforce them. WAF · 5a917e1f · Security · Azure Landing Zone Review	
● Non-compliant via finding	● Medium	Enable firewall and virtual network service endpoint or private endpoint on the vault to control access to the key vault. WAF · cdb3751a · Security · Azure Landing Zone Review	
● Non-compliant	● Medium	Deploy Private Endpoints to filter incoming traffic when APIM is not deployed to a VNet. WAF · 67437a28 · Security · Azure API Management Review	2 × / 0 ✓
● Non-compliant	● Medium	Use managed identities to authenticate to other Azure resources whenever possible WAF · 791abd8b · Security · Azure API Management Review	2 × / 0 ✓
● Non-compliant	● Low	Set Patch orchestration options to Azure-orchestrated APRL · e4ffd7b0 · Other Best Practices · Microsoft.Compute/virtualMachineScaleSets	2 × / 0 ✓
● Non-compliant	● Low	Deploy Network Watcher in all regions where you have networking services APRL · 4e133bd0 · Monitoring and Alerting · Microsoft.Network/networkWatchers	2 × / 0 ✓
● Non-compliant	● Low	Fix Flow Log configurations in Failed state or Disabled Status APRL · 22a769ed · Monitoring and Alerting · Microsoft.Network/networkWatchers	2 × / 0 ✓
● Non-compliant	● Low	Replicate your Image Templates to a secondary region APRL · 21fb841b · Disaster Recovery · Microsoft.VirtualMachineImages/imageTemplates	1 × / 0 ✓
● Non-compliant	● Low	Consider AKS virtual node for quick bursting WAF · c755562f · Operations · Azure AKS Review	1 × / 0 ✓
● Partially compliant	● High	When deploying Active Directory Domain Controllers, use a location with Availability Zones and deploy at least two VMs across these zones. If not available, deploy in an Availability Set. ALZ · B03.09 · Identity and Access Management · Identity	1 × / 5 ✓
● Partially compliant	● High	Configure Identity network segmentation through the use of a virtual Network and peer back to the hub. Providing authentication inside application landing zone (legacy). ALZ · B04.01 · Identity and Access Management · Landing zones	1 × / 3 ✓
● Partially compliant	● High	Use the setting 'Allow traffic to remote virtual network' when configuring VNet peerings. ALZ · D01.13 · Network Topology and Connectivity · Hub and spoke	2 × / 2 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Partially compliant	● High	Ensure that IP address space isn't wasted, don't create unnecessarily large virtual networks (for example /16). ALZ · D03.03 · Network Topology and Connectivity · IP plan	3 × / 1 ✓
● Partially compliant	● High	Leverage the Local SKU of ExpressRoute to reduce the cost of your circuits, if your circuit peering location supports your Azure regions for the Local SKU. ALZ · D06.05 · Network Topology and Connectivity · Hybrid	1 × / 1 ✓
● Partially compliant	● High	Use Azure Firewall Premium to enable additional security features. ALZ · D07.05 · Network Topology and Connectivity · Firewall	1 × / 1 ✓
● Partially compliant	● High	For subnets in VNets not connected to Virtual WAN, attach a route table so that Internet traffic is redirected to Azure Firewall or a Network Virtual Appliance. ALZ · D07.08 · Network Topology and Connectivity · Firewall	1 × / 3 ✓
● Partially compliant	● High	Use a /26 prefix for your Azure Firewall subnets. ALZ · D07.11 · Network Topology and Connectivity · Segmentation	1 × / 3 ✓
● Partially compliant	● High	Don't enable virtual network service endpoints by default on all subnets. ALZ · D08.04 · Network Topology and Connectivity · PaaS	1 × / 3 ✓
● Partially compliant	● High	Use at least a /27 prefix for your Gateway subnets. ALZ · D09.01 · Network Topology and Connectivity · Segmentation	3 × / 1 ✓
● Partially compliant via finding	● High	Enable Defender Cloud Security Posture Management (CSPM) plan for all resources in addition to the on-by-default Foundational plan for advanced security posture features . ALZ · G03.03 · Security · Operations	
● Partially compliant	● High	Run production workloads on two or more VMs using VMSS Flex APRL · 273f6b30 · High Availability · Microsoft.Compute/virtualMachines	1 × / 5 ✓
● Partially compliant	● High	Migrate VMs using availability sets to VMSS Flex APRL · a8d25876 · High Availability · Microsoft.Compute/virtualMachines	2 × / 4 ✓
● Partially compliant	● High	Use Managed Disks for VM disks APRL · 122d11d7 · High Availability · Microsoft.Compute/virtualMachines	4 × / 2 ✓
● Partially compliant	● High	Use maintenance configurations for the VMs APRL · 52ab9e5c · High Availability · Microsoft.Compute/virtualMachines	3 × / 3 ✓
● Partially compliant	● High	Don't use A or B-Series VMs for production needing constant full CPU performance APRL · 3201dba8 · Scalability · Microsoft.Compute/virtualMachines	2 × / 4 ✓
● Partially compliant	● High	Mission Critical Workloads should consider using Premium or Ultra Disks APRL · df0ff862 · Scalability · Microsoft.Compute/virtualMachines	3 × / 3 ✓
● Partially compliant	● High	Key vaults should have soft delete enabled APRL · 1cca00d2 · Disaster Recovery · Microsoft.KeyVault/vaults	1 × / 2 ✓
● Partially compliant	● High	Use Standard SKU and Zone-Redundant IPs when applicable APRL · c63b81fb · High Availability · Microsoft.Network/publicIPAddresses	1 × / 3 ✓
● Partially compliant	● High	Ensure that storage accounts are zone or region redundant APRL · e6c7e1cc · High Availability · Microsoft.Storage/storageAccounts	1 × / 8 ✓
● Partially compliant	● High	Do not create more than 2000 Citrix VDA servers per subscription APRL · c041d596 · Governance · Microsoft.Subscription/Subscriptions	1 × / 2 ✓
● Partially compliant	● High	Set up ExpressRoute connections from on-premises to the primary and secondary Azure disaster recovery regions. Also, as an alternative to using ExpressRoute, consider setting up VPN connections from on-premises to the primary and secondary Azure disaster recovery regions. WAF · ba07c007 · Reliability · SAP Checklist	1 × / 1 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Partially compliant	● High	The CIDR for the primary virtual network (VNet) shouldn't conflict or overlap with the CIDR of the DR site's VNet WAF · 6561f847 · Reliability · SAP Checklist	2 X / 2 ✓
● Partially compliant	● High	Azure AI search service tiers should be chosen to have a SLA WAF · 95b96ad8 · Reliability · AI Landing Zone	1 X / 1 ✓
● Partially compliant	● High	Turn off remote debugging in production environments. WAF · d9bd3baf · Security · Azure App Service Review	3 X / 2 ✓
● Partially compliant	● High	Use the same domain name on Azure Front Door and your origin. Mismatched host names can cause subtle bugs. WAF · 5efeb96a · Security · Azure Application Delivery Networking	1 X / 1 ✓
● Partially compliant	● High	Use managed TLS certificates with Azure Front Door. Reduce operational cost and risk of outages due to certificate renewals. WAF · af95c92d · Operations · Azure Application Delivery Networking	1 X / 1 ✓
● Partially compliant	● High	Use end-to-end TLS with Azure Front Door. Use TLS for connections from your clients to Front Door, and from Front Door to your origin. WAF · 2e30abab · Security · Azure Application Delivery Networking	1 X / 1 ✓
● Partially compliant	● High	Use the setting 'Allow traffic to remote virtual network' when configuring VNet peerings. WAF · c76cb5a2 · Reliability · Azure Landing Zone Review	2 X / 2 ✓
● Partially compliant	● High	Ensure that IP address space isn't wasted, don't create unnecessarily large virtual networks (for example /16). WAF · 33aad5e8 · Performance · Azure Landing Zone Review	3 X / 1 ✓
● Partially compliant	● High	Leverage the Local SKU of ExpressRoute to reduce the cost of your circuits, if your circuit peering location supports your Azure regions for the Local SKU. WAF · f4e7926a · Cost · Azure Landing Zone Review	1 X / 1 ✓
● Partially compliant	● High	Use Azure Firewall Premium to enable additional security features. WAF · c10d51ef · Security · Azure Landing Zone Review	1 X / 1 ✓
● Partially compliant	● High	For subnets in VNets not connected to Virtual WAN, attach a route table so that Internet traffic is redirected to Azure Firewall or a Network Virtual Appliance. WAF · a3784907 · Security · Azure Landing Zone Review	1 X / 3 ✓
● Partially compliant	● High	Use a /26 prefix for your Azure Firewall subnets. WAF · 22d6419e · Security · Azure Landing Zone Review	1 X / 3 ✓
● Partially compliant	● High	Don't enable virtual network service endpoints by default on all subnets. WAF · 4704489a · Security · Azure Landing Zone Review	1 X / 3 ✓
● Partially compliant	● High	Use at least a /27 prefix for your Gateway subnets. WAF · f2aad7e3 · Security · Azure Landing Zone Review	3 X / 1 ✓
● Partially compliant via finding	● High	Enable Defender Cloud Security Posture Management (CSPM) plan for all resources in addition to the on-by-default Foundational plan for advanced security posture features . WAF · 09945bda · Security · Azure Landing Zone Review	
● Partially compliant	● High	Consider using private endpoints for Azure Storage WAF · f42d78e7 · Security · Azure Storage Review Checklist	1 X / 8 ✓
● Partially compliant	● High	Enable Microsoft Defender for all of your storage accounts WAF · fc5972cd · Security · Azure Storage Review Checklist	2 X / 7 ✓
● Partially compliant	● High	Enforce the latest TLS version for a storage account WAF · e12be569 · Security · Azure Storage Review Checklist	4 X / 5 ✓
● Partially compliant	● High	Consider disabling storage account keys, so that only Microsoft Entra ID access (and user delegation SAS) is supported. WAF · 15f51296 · Security · Azure Storage Review Checklist	3 X / 6 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Partially compliant	● High	Consider whether public blob anonymous access is needed, or whether it can be disabled for certain storage accounts. WAF · 659ae558 · Security · Azure Storage Review Checklist	6 × / 3 ✓
● Partially compliant	● High	Leverage GRS, ZRS or GZRS storage for the highest availability WAF · e05bbe20 · Reliability · Azure Storage Review Checklist	4 × / 5 ✓
● Partially compliant	● Medium	Use Azure custom RBAC roles for the following key roles to provide fine-grain access across your ALZ: Azure platform owner, network management, security operations, subscription owner, application owner. Align these roles to teams and responsibilities within your business. ALZ · B03.11 · Identity and Access Management · Identity	1 × / 1 ✓
● Partially compliant via finding	● Medium	Use Azure RBAC to manage data plane access to resources, if possible. E.g. Data Operations across Key Vault, Storage Account and Database Services. ALZ · B04.02 · Identity and Access Management · Landing zones	
● Partially compliant via finding	● Medium	Enforce a platform management group under the root management group to support common platform policy and Azure role assignment. ALZ · C02.03 · Resource Organization · Subscriptions	
● Partially compliant	● Medium	Limit the number of routes per route table to 400. ALZ · D01.12 · Network Topology and Connectivity · Hub and spoke	1 × / 1 ✓
● Partially compliant	● Medium	Use IP addresses from the address allocation ranges for private internets (RFC 1918). ALZ · D03.02 · Network Topology and Connectivity · IP plan	3 × / 1 ✓
● Partially compliant	● Medium	Enable VNet Flow Logs and feed them into Traffic Analytics to gain insights into internal and external traffic flows. ALZ · D09.06 · Network Topology and Connectivity · Segmentation	3 × / 1 ✓
● Partially compliant	● Medium	Do not implement more than 900 NSG rules per NSG, due to the limit of 1000 rules. ALZ · D09.07 · Network Topology and Connectivity · Segmentation	3 × / 4 ✓
● Partially compliant	● Medium	Use AS-Path as hub routing preference, since it is more flexible than ExpressRoute or VPN. ALZ · D10.07 · Network Topology and Connectivity · Virtual WAN	1 × / 1 ✓
● Partially compliant via finding	● Medium	Establish Azure Policy definitions at the intermediate root management group so that they can be assigned at inherited scopes. ALZ · E01.04 · Governance · Governance	
● Partially compliant via finding	● Medium	Configure 'Actual' and 'Forecasted' Budget Alerts. ALZ · E02.01 · Governance · Optimize your cloud investment	
● Partially compliant via finding	● Medium	Use resource locks to prevent accidental deletion of critical shared services. ALZ · F01.08 · Management · Monitoring	
● Partially compliant via finding	● Medium	Include service and resource health events as part of the overall platform monitoring solution. Tracking service and resource health from the platform perspective is an important component of resource management in Azure. ALZ · F01.10 · Management · Monitoring	
● Partially compliant via finding	● Medium	Include alerts and action groups as part of the Azure Service Health platform to ensure that alerts or issues can be actioned. ALZ · F01.11 · Management · Monitoring	
● Partially compliant via finding	● Medium	Provision Azure Key Vault with the soft delete and purge policies enabled to allow retention protection for deleted objects. ALZ · G02.03 · Security · Encryption and keys	
● Partially compliant via finding	● Medium	Export Azure activity logs to Azure Monitor Logs for long-term data retention. Export to Azure Storage for long-term storage beyond 12 years, if necessary. ALZ · G03.02 · Security · Operations	

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Partially compliant	● Medium	Replicate VMs using Azure Site Recovery APRL · cfe22a65 · Disaster Recovery · Microsoft.Compute/virtualMachines	3 × / 3 ✓
● Partially compliant	● Medium	Backup VMs with Azure Backup service APRL · 1981f704 · Disaster Recovery · Microsoft.Compute/virtualMachines	1 × / 5 ✓
● Partially compliant	● Medium	Enable Accelerated Networking (AcceNet) APRL · dfedbeb1 · Scalability · Microsoft.Compute/virtualMachines	1 × / 5 ✓
● Partially compliant	● Medium	VMs should not have a Public IP directly associated APRL · 1f629a30 · Security · Microsoft.Compute/virtualMachines	5 × / 1 ✓
● Partially compliant	● Medium	IP Forwarding should only be enabled for Network Virtual Appliances APRL · 41a22a5e · Security · Microsoft.Compute/virtualMachines	2 × / 4 ✓
● Partially compliant	● Medium	Shared disks should only be enabled in clustered servers APRL · 3263a64a · Other Best Practices · Microsoft.Compute/virtualMachines	2 × / 4 ✓
● Partially compliant	● Medium	Key vaults should have purge protection enabled APRL · 70fcfe6d · Disaster Recovery · Microsoft.KeyVault/vaults	1 × / 2 ✓
● Partially compliant	● Medium	Configure NSG Flow Logs APRL · da1a3c06 · Monitoring and Alerting · Microsoft.Network/networkSecurityGroups	1 × / 6 ✓
● Partially compliant	● Medium	The NSG only has Default Security Rules, make sure to configure the necessary rules APRL · 8291c1fa · Security · Microsoft.Network/networkSecurityGroups	3 × / 4 ✓
● Partially compliant	● Medium	Public IP addresses should have DDoS protection enabled APRL · c4254c66 · Security · Microsoft.Network/publicIPAddresses	1 × / 3 ✓
● Partially compliant	● Medium	Enable Azure Private Link service for storage accounts APRL · dc55be60 · Security · Microsoft.Storage/storageAccounts	6 × / 3 ✓
● Partially compliant	● Medium	Store configuration as app settings APRL · 0b80b67c · Other Best Practices · Microsoft.Web/sites	3 × / 2 ✓
● Partially compliant	● Medium	Configure network access restrictions APRL · aab6b4a4 · Governance · Microsoft.Web/sites	1 × / 4 ✓
● Partially compliant	● Medium	Set minimum instance count to 2 for app service APRL · 9e6682ac · Scalability · Microsoft.Web/sites	1 × / 4 ✓
● Partially compliant	● Medium	Use DDoS Standard in the AKS Virtual Network WAF · 9bda4776 · Security · Azure AKS Review	2 × / 2 ✓
● Partially compliant	● Medium	Your Application Gateways v2 should be deployed in subnets with IP prefixes equal or larger than /24 WAF · dfc50f87 · Security · Azure Application Delivery Networking	1 × / 3 ✓
● Partially compliant	● Medium	Avoid VM SKUs with temp disk offerings. Service Fabric uses managed disks by default, so avoiding temp disk offerings ensures you don't pay for unneeded resources. WAF · 4da21268 · Cost · Azure Service Fabric Review Checklist	5 × / 1 ✓
● Partially compliant	● Medium	Deploy Key Vault certificates to Service Fabric cluster virtual machine scale sets. Centralizing storage of application secrets in Azure Key Vault allows you to control their distribution. Key Vault greatly reduces the chances that secrets may be accidentally leaked. WAF · 4e98c903 · Security · Azure Service Fabric Review Checklist	2 × / 4 ✓
● Partially compliant	● Medium	Local and global VNet peering provide connectivity and are the preferred approaches to ensure connectivity between landing zones for SAP deployments across multiple Azure regions WAF · a3592829 · Reliability · SAP Checklist	3 × / 1 ✓

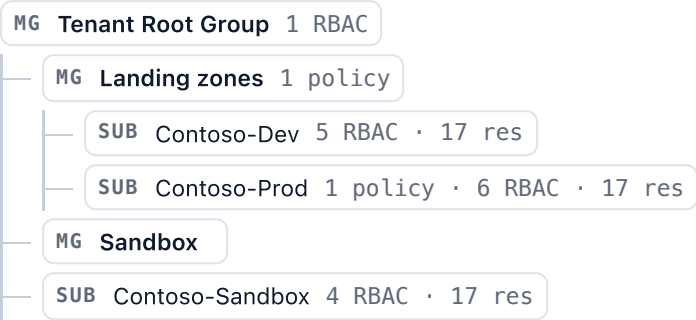
RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Partially compliant	● Medium	Use Virtual WAN for Azure deployments in new, large, or global networks where you need global transit connectivity across Azure regions and on-premises locations. With this approach, you won't need to manually set up transitive routing for Azure networking, and you can follow a standard for SAP on Azure deployments. WAF · 7d4bc7d2 · Operations · SAP Checklist	1 × / 1 ✓
● Partially compliant	● Medium	Use Premium and Standard tiers for staging slots and automated backups. Align your backup retention period with disaster recovery needs. WAF · e4b31c6a · Reliability · Azure App Service Review	1 × / 1 ✓
● Partially compliant	● Medium	Set minimum TLS policy to 1.2 or higher, preferably 1.3, in App Service configuration. WAF · c115775c · Security · Azure App Service Review	1 × / 4 ✓
● Partially compliant	● Medium	Use Azure Front Door with WAF policies to deliver and help protect global HTTP/S apps that span multiple Azure regions. WAF · e79d17b7 · Security · Azure Application Delivery Networking	1 × / 1 ✓
● Partially compliant	● Medium	Limit the number of routes per route table to 400. WAF · 3d457936 · Reliability · Azure Landing Zone Review	1 × / 1 ✓
● Partially compliant	● Medium	Use IP addresses from the address allocation ranges for private internets (RFC 1918). WAF · 3f630472 · Security · Azure Landing Zone Review	3 × / 1 ✓
● Partially compliant	● Medium	Enable VNet Flow Logs and feed them into Traffic Analytics to gain insights into internal and external traffic flows. WAF · dfe237de · Security · Azure Landing Zone Review	3 × / 1 ✓
● Partially compliant	● Medium	Do not implement more than 900 NSG rules per NSG, due to the limit of 1000 rules. WAF · 0390417d · Reliability · Azure Landing Zone Review	3 × / 4 ✓
● Partially compliant	● Medium	Use AS-Path as hub routing preference, since it is more flexible than ExpressRoute or VPN. WAF · d49ac006 · Reliability · Azure Landing Zone Review	1 × / 1 ✓
● Partially compliant via finding	● Medium	Establish Azure Policy definitions at the intermediate root management group so that they can be assigned at inherited scopes. WAF · 223ace8c · Security · Azure Landing Zone Review	
● Partially compliant via finding	● Medium	Provision Azure Key Vault with the soft delete and purge policies enabled to allow retention protection for deleted objects. WAF · 2ba52752 · Security · Azure Landing Zone Review	
● Partially compliant	● Medium	For DR, leverage the premium tier with deployments scaled across two or more regions for 99.99% SLA WAF · beae759e · Reliability · Azure API Management Review	1 × / 1 ✓
● Partially compliant	● Low	If using Route Server, use a /27 prefix for the Route Server subnet. ALZ · D01.08 · Network Topology and Connectivity · Hub and spoke	2 × / 2 ✓
● Partially compliant via finding	● Low	Use Azure Policy to control which services users can provision at the subscription/management group level. ALZ · E01.06 · Governance · Governance	
● Partially compliant via finding	● Low	Use deny policies to supplement Azure role assignments. The combination of deny policies and Azure role assignments ensures the appropriate guardrails are in place to enforce who can deploy and configure resources and what resources they can deploy and configure. ALZ · F01.09 · Management · Monitoring	
● Partially compliant	● Low	Host database data on a data disk APRL · 4ea2878f · Scalability · Microsoft.Compute/virtualMachines	3 × / 3 ✓
● Partially compliant	● Low	Review VMs in stopped state APRL · 98b334c0 · Governance · Microsoft.Compute/virtualMachines	1 × / 5 ✓

RESULT	SEVERITY	RECOMMENDATION	RESOURCES
● Partially compliant	● Low	Customer DNS Servers should be configured in the Virtual Network level APRL · 1cf8fe21 · Other Best Practices · Microsoft.Compute/virtualMachines	1 X / 5 ✓
● Partially compliant	● Low	Network access to the VM disk should be set to Disable public access and enable private access APRL · 70b1d2be · Security · Microsoft.Compute/virtualMachines	1 X / 5 ✓
● Partially compliant	● Low	Ensure that your VMs are compliant with Azure Policies APRL · c42343ae · Governance · Microsoft.Compute/virtualMachines	1 X / 5 ✓
● Partially compliant	● Low	Enable VM Insights APRL · b72214bb · Monitoring and Alerting · Microsoft.Compute/virtualMachines	2 X / 4 ✓
● Partially compliant	● Low	Configure monitoring for all Azure Virtual Machines APRL · 4a9d8973 · Monitoring and Alerting · Microsoft.Compute/virtualMachines	2 X / 4 ✓
● Partially compliant	● Low	Monitor changes in Network Security Groups with Azure Monitor APRL · 8bb4a57b · Monitoring and Alerting · Microsoft.Network/networkSecurityGroups	5 X / 2 ✓
● Partially compliant	● Low	All Subnets should have a Network Security Group associated APRL · f0bf9ae6 · Security · Microsoft.Network/virtualNetworks	2 X / 2 ✓
● Partially compliant	● Low	Consider upgrading legacy storage accounts to v2 storage accounts APRL · 2ad78dec · Scalability · Microsoft.Storage/storageAccounts	2 X / 7 ✓
● Partially compliant	● Low	Deploy to a staging slot APRL · a1d91661 · Governance · Microsoft.Web/sites	1 X / 4 ✓
● Partially compliant	● Low	If required add company HTTP Proxy WAF · 6c46b91a · Security · Azure AKS Review	2 X / 2 ✓
● Partially compliant	● Low	Azure AI Services are properly tagged for better management WAF · e1d7aaab · Operations · AI Landing Zone	1 X / 1 ✓
● Partially compliant	● Low	Disable health probes when there is only one origin in an Azure Front Door origin group. WAF · 0b5a380c · Performance · Azure Application Delivery Networking	1 X / 1 ✓
● Partially compliant	● Low	Use HEAD health probes with Azure Front Door, to reduce the traffic that Front Door sends to your application. WAF · a13f72f3 · Performance · Azure Application Delivery Networking	1 X / 1 ✓
● Partially compliant	● Low	If using Route Server, use a /27 prefix for the Route Server subnet. WAF · 91b9d7d5 · Security · Azure Landing Zone Review	2 X / 2 ✓
● Partially compliant via finding	● Low	Use Azure Policy to control which services users can provision at the subscription/management group level. WAF · 43334f24 · Security · Azure Landing Zone Review	

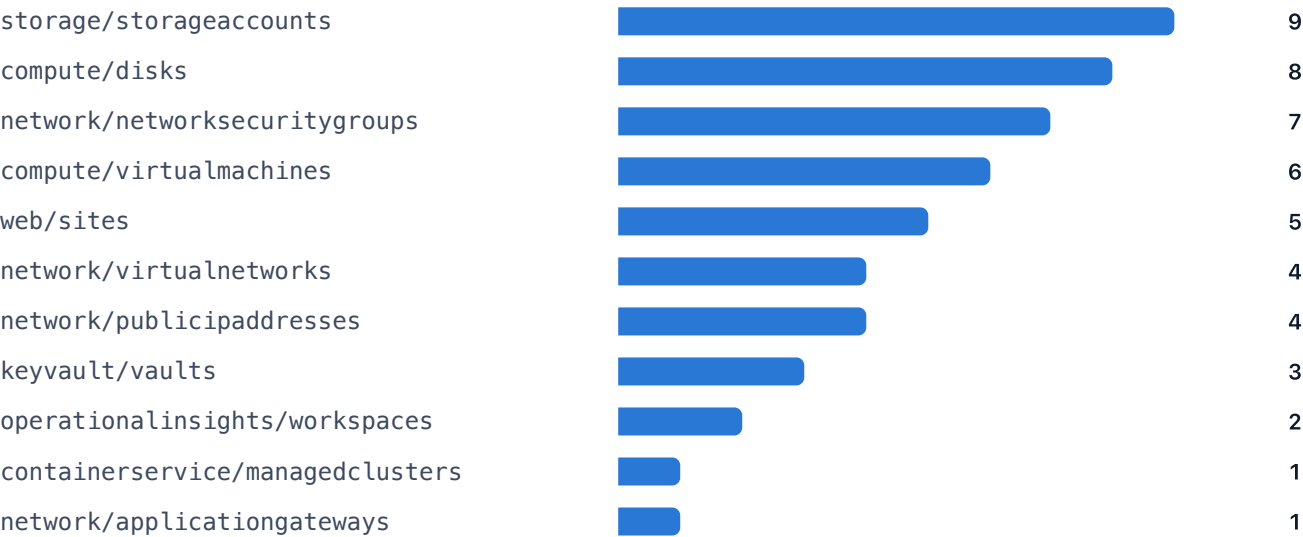
7 Environment

What was assessed: hierarchy, subscriptions and resources.

Management group hierarchy



Resources by type



Resources by region



Subscriptions

Subscription	ID	Management Group Path	Resources	RGS	Secure Score	Defender Plans On	Budget	Activity Log Export
Contoso-Dev	aaaaaaaa-0000-0000-000000000002	Tenant Root Group	17	4	46%	2	no	no
Contoso-Prod	aaaaaaaa-0000-0000-000000000001	Tenant Root Group	17	4	36%	3	yes	yes

SUBSCRIPTION	ID	MANAGEMENT GROUP PATH	RESOURCES	RGS	SECURE SCORE	DEFENDER PLANS ON	BUDGET	ACTIVITY LOG EXPORT
Contoso-Sandbox	aaaaaaaa-0000-0000-000000000003	Tenant Root Group	17	4	56%	3	no	no

Azure Advisor recommendations

CATEGORY	IMPACT	RECOMMENDATION	RESOURCES
Security	High	Enable soft delete for blobs	5
Cost	Medium	Right-size underutilized VMs	2

Defender for Cloud – unhealthy assessments

DEFENDER FOR CLOUD RECOMMENDATION	SEVERITY	UNHEALTHY RESOURCES
Storage accounts should restrict network access	Medium	6
MFA should be enabled on accounts with owner permissions	High	2

8 Method and sources

How this assessment was produced

1. **AzGovViz** 6.7.2 collected the management group hierarchy, Azure Policy, RBAC, Defender for Cloud, network and resource data read-only.
2. **Azure Resource Graph** provided inventory, Defender for Cloud, Advisor, policy-state and configuration evidence.
3. **Azure review checklists** (ALZ, WAF, APRL) were evaluated with 325 Resource Graph queries from commit `f131b93` .
4. Findings are scored by severity (high 3, medium 2, low 1; warnings earn half credit). Design-area scores blend tenant checks (60%) and checklist results (40%); the overall score is the mean of assessed design areas.
5. Maturity levels: Initial <40, Developing 40–59, Defined 60–74, Managed 75–89, Optimized ≥90.

Run details

Run folder	/private/tmp/azgov-demo/contoso_fake_full
Generated	2026-10-08T14:29:31Z
Tool	azgovviz-assessment 1.0.0 (GitHub Copilot CLI plugin)
Signed-in identity	–
Token source	fake
Raw data	AzGovViz HTML report · findings.json · brief.md · checklists/results.json · inventory.json

Limitations

- AI analysis notes: Synthetic demo tenant (token provider 'fake'); the AzGovViz output was supplied rather than collected in this run. The automated checklist results only partly reconcile with the Resource Graph inventory: several failing items refer to services that do not appear in the inventory (Azure VMware Solution, Azure NetApp Files, API Management, VM scale sets, ExpressRoute, Front Door), and some counts disagree with resource properties (WAF e05bbe20 reports 5 compliant storage accounts while the inventory lists all 9 as Standard_LRS; AzGovViz flags 1 orphaned disk in Contoso-Dev while Resource Graph lists 2 unattached disks there). This analysis therefore relies on platform findings and inventory and cites only checklist items consistent with them. 206 of 255 ALZ items and 1119 of 1268 WAF items are manual and were not evaluated. Defender for Cloud's MFA recommendation does not name the 2 affected owner accounts; confirm them in the portal.
- Checklist queries return what the signed-in identity can read; items without a query need human review.